

TRƯỜNG ĐẠI HỌC XÂY DỰNG HÀ NỘI
KHOA CÔNG NGHỆ THÔNG TIN
BỘ MÔN AN TOÀN THÔNG TIN



BÀI TẬP LỚN MÔN: AN TOÀN BẢO MẬT THÔNG TIN

Ngành: Khoa học Máy tính

**ỨNG DỤNG HỌC MÁY TRONG PHÁT HIỆN TẤN
CÔNG BRUTE FORCE TỪ DỮ LIỆU LƯU LƯỢNG
MẠNG SỬ DỤNG CICIDS2017**

**(MACHINE LEARNING FOR BRUTE FORCE ATTACK DETECTION IN
NETWORK FLOW TRAFFIC USING CICIDS2017)**

Giảng viên hướng dẫn: Nguyễn Việt Nhật

Nhóm sinh viên thực hiện:

Họ và tên sinh viên	Mã số sinh viên
Trần Phùng Đức Anh	0204168
Nguyễn Thu Hương	0209168
Nguyễn Việt Tuấn Anh	
Nguyễn Vũ Dũng	
Võ Nguyễn Anh Kiệt	

HÀ NỘI, 2026

LỜI CAM ĐOAN

Chúng tôi xin cam đoan rằng bài tập lớn với đề tài: “**ỨNG DỤNG HỌC MÁY TRONG PHÁT HIỆN TẤN CÔNG BRUTE FORCE TỪ DỮ LIỆU LƯU LƯỢNG MẠNG SỬ DỤNG CICIDS2017**” là công trình nghiên cứu và thực nghiệm được nhóm chúng tôi thực hiện một cách nghiêm túc, độc lập dưới sự hướng dẫn của thầy **Nguyễn Việt Nhật**.

Mọi số liệu thực nghiệm, kết quả đo lường và các phát hiện được trình bày trong báo cáo này đều có nguồn gốc minh bạch, được truy xuất trực tiếp từ các artifact đã được kiểm chứng và khóa mã nguồn trong repository công khai của đề tài. Các kết quả dù đạt hiệu năng cao hay suy giảm nghiêm trọng trong các kịch bản thực tế đều được ghi nhận trung thực, không qua chỉnh sửa hay ngụy tạo nhằm mục đích làm đẹp báo cáo.

Các nguồn tài liệu tham khảo, các nghiên cứu đi trước và các công cụ mã nguồn mở được sử dụng đều đã được trích dẫn đầy đủ và rõ ràng theo chuẩn mực học thuật quốc tế. Nhóm chúng tôi hoàn toàn chịu trách nhiệm trước Bộ môn và Nhà trường về tính trung thực của lời cam đoan này.

HÀ NỘI, Tháng 09 năm 2026

Nhóm sinh viên thực hiện

(Ký và ghi rõ họ tên)

Trần Phùng Đức Anh

Nguyễn Thu Hương

Nguyễn Việt Tuấn Anh

Nguyễn Vũ Dũng

Võ Nguyễn Anh Kiệt

LỜI CẢM ƠN

Để hoàn thành bài tập lớn môn học này, chúng tôi xin bày tỏ lòng biết ơn sâu sắc nhất tới các thầy cô giáo tại TRƯỜNG ĐẠI HỌC XÂY DỰNG HÀ NỘI, đặc biệt là các thầy cô thuộc KHOA CÔNG NGHỆ THÔNG TIN và BỘ MÔN AN TOÀN THÔNG TIN, những người đã tận tâm truyền đạt những kiến thức nền tảng quý báu về khoa học máy tính, an toàn bảo mật thông tin và mạng máy tính trong suốt quá trình học tập.

Đặc biệt, nhóm chúng tôi xin gửi lời cảm ơn chân thành và sâu sắc nhất tới thầy **Nguyễn Việt Nhật**, người đã trực tiếp giảng dạy, định hướng khoa học, tận tình hướng dẫn phương pháp nghiên cứu thực nghiệm và đóng góp những nhận xét chuyên môn quý giá giúp chúng tôi hoàn thiện bài tập lớn này một cách chuẩn mực và khách quan nhất.

Cuối cùng, chúng tôi xin gửi lời cảm ơn tới toàn thể các bạn sinh viên trong lớp đã luôn trao đổi, hỗ trợ và chia sẻ tài liệu trong suốt thời gian thực hiện đề tài.

HÀ NỘI, Tháng 09 năm 2026

Nhóm sinh viên thực hiện

*Nguyễn Việt Tuấn Anh, Nguyễn Thu Hương, Nguyễn Vũ Dũng,
Trần Phùng Đức Anh, Võ Nguyễn Anh Kiệt*

TÓM TẮT BÁO CÁO

Trong những năm gần đây, ứng dụng học máy (Machine Learning - ML) trong các hệ thống phát hiện xâm nhập mạng (Network Intrusion Detection Systems - NIDS) là một trong những hướng tiếp cận nhận được sự quan tâm lớn. Tuy nhiên, phần lớn các công bố học thuật sử dụng chiến lược phân chia dữ liệu ngẫu nhiên (Random Split) thường báo cáo điểm số F1-Score vượt trội ($> 99\%$), tạo ra một bức tranh hiệu năng quá mức lạc quan (Optimistic Evaluation Bias) và tiềm ẩn nguy cơ thất bại nghiêm trọng khi triển khai trong môi trường mạng thực tế.

Nghiên cứu này tiến hành một cuộc đánh giá thực nghiệm toàn diện và nghiêm ngặt đối với bài toán phát hiện tấn công dò quét mật khẩu (Brute Force: FTP-Patator và SSH-Patator) trên tập dữ liệu chuẩn CICIDS2017 (phần dữ liệu ngày thứ Ba - Tuesday Working Hours). Bằng việc áp dụng chiến lược phân tách theo thời gian (Time-based Split) kết hợp với kỹ thuật làm sạch ranh giới bảo thủ (Purge $q = 60s$ và Embargo $g = 120s$), bài toán được thiết lập thành một kịch bản **Zero-Shot Subtype Transfer** thực tế: Mô hình chỉ được học trên tấn công FTP-Patator diễn ra vào buổi sáng và phải nhận diện dạng tấn công SSH-Patator hoàn toàn mới xuất hiện vào buổi chiều.

Kết quả thực nghiệm trên 3 mô hình học máy dạng cây (Decision Tree, Random Forest, XGBoost) đã chỉ ra một sự sụp đổ hiệu năng nghiêm trọng: Điểm F1-Score trên tập Test theo thời gian chỉ đạt tối đa 0.0037 đối với mô hình chiến thắng (Random Forest) với tỷ lệ bắt giữ tấn công SSH chỉ đạt 0.19% (chỉ nhận diện được 7 trên tổng số 3,732 flow SSH). Phân tích khả năng giải thích bằng SHAP TreeExplainer và cấu trúc cây quyết định chứng minh rằng các mô hình đã phụ thuộc tuyệt đối vào cổng dịch vụ (Destination Port chiếm giá trị SHAP cao nhất, gấp 3.6 lần đặc trưng thứ hai). Khi loại bỏ thông tin cổng (Port Ablation), các đặc trưng thống kê kích thước gói tin và thời gian vẫn không đủ để mô hình tổng quát hóa do sự khác biệt cơ bản về cấu trúc giao thức giữa FTP và SSH.

Ngược lại, trên tập đối chứng phân tách ngẫu nhiên, các mô hình dễ dàng đạt điểm F1-Score từ 0.9823 đến 0.9997 do hiện tượng rò rỉ phân phối và lặp lại chiến dịch tấn công. Báo cáo cũng làm rõ một case study điển hình trong MLOps: việc công cụ tự động kích hoạt cơ chế huấn luyện lại (`refit=True`) trên tập gộp Train + Validation đã vô tình làm rò rỉ 1,886 mẫu SSH từ Validation vào mô hình, đẩy F1 từ 0.0 lên 0.9912. Nghiên cứu đúc kết những bài học thực tiễn then chốt trong việc quản trị ranh giới dữ liệu và đề xuất quy trình đánh giá chuẩn mực cho các hệ thống NIDS dựa trên học máy.

Từ khóa: Hệ thống phát hiện xâm nhập mạng (NIDS), CICIDS2017, Tấn công Brute Force, Phân tách theo thời gian (Time-based Split), Data Leakage, Zero-Shot Transfer, Khả năng giải thích mô hình (SHAP).

ABSTRACT

In recent years, the application of Machine Learning (ML) to Network Intrusion Detection Systems (NIDS) has garnered widespread interest. However, most existing academic studies employing random data partitioning report near-perfect F1-scores ($> 99\%$), introducing substantial optimistic evaluation bias and concealing the risk of catastrophic failure in real-world deployments.

This study conducts a rigorous, transparent empirical evaluation of brute force attack detection (`FTP-Patator` and `SSH-Patator`) using the benchmark CICIDS2017 Tuesday dataset. By implementing a strict time-based split combined with conservative boundary purge ($q = 60\text{s}$) and embargo ($g = 120\text{s}$) mechanisms, we formulate a realistic **Zero-Shot Subtype Transfer** benchmark: models are trained strictly on morning `FTP-Patator` attacks and subsequently evaluated on afternoon `SSH-Patator` attacks, which are completely unobserved during training.

Empirical evaluation across three tree-based algorithms (Decision Tree, Random Forest, and XGBoost) reveals a catastrophic performance collapse: the top model (Random Forest) achieves an F1-score of only 0.0037 on the canonical temporal test set, capturing merely 7 out of 3,732 SSH flows (0.19%). Interpretability analyses via SHAP TreeExplainer and tree topology demonstrate that models heavily overfit to service ports (`Destination Port` exhibits the highest mean $|\text{SHAP}|$ attribution, 3.6 times higher than the second feature). When service ports are eliminated via port ablation, packet length and inter-arrival time statistics remain insufficient for cross-protocol generalization due to fundamental differences between FTP and SSH traffic signatures.

Conversely, under conventional random splitting controls, models attain artificially inflated F1-scores of 0.9823 – 0.9997 caused by campaign-level autocorrelation and identical traffic footprints spanning both training and test partitions. Furthermore, we investigate an instructive MLOps case study wherein default scikit-learn `refit=True` behavior re-trains models on concatenated Train and Validation sets, exposing the classifier to 1,886 validation SSH flows and causing the test F1-score to surge from 0.0 to 0.9912. This research underscores essential methodological principles for temporal leakage prevention, data boundary governance, and authentic NIDS evaluation.

Keywords: Network Intrusion Detection Systems (NIDS), CICIDS2017, Brute Force At-

tacks, Temporal Split, Data Leakage, Zero-Shot Transfer, Explainable AI (SHAP).

MỤC LỤC

Lời Cam Đoan	i
Lời Cảm Ơn	ii
Tóm Tắt Báo Cáo	iii
Abstract	v
Danh Mục Ký Hiệu và Chữ Viết Tắt	xiii
1 Giới Thiệu và Đặt Vấn Đề	1
1.1 Bối Cảnh An Ninh Mạng và Nguy Cơ Tấn Công Brute Force	1
1.2 Từ Signature-based sang Học Máy trong Flow-based NIDS	1
1.3 Vấn Đề Khoa Học: Đánh Giá Lạc Quan và Thách Thức Thời Gian	2
1.4 Mục Tiêu Nghiên Cứu và Câu Hỏi Nghiên Cứu (RQs)	3
1.5 Đóng Góp của Đề Tài	3
1.6 Cấu Trúc của Báo Cáo	4
2 Cơ Sở Lý Thuyết	5
2.1 Bản Chất Lưu Lượng Mạng và Cơ Chế Flow-Based Inspection	5
2.1.1 Khái niệm Luồng Mạng (IP Network Flow)	5
2.1.2 Cơ chế sinh đặc trưng của CICFlowMeter	5
2.1.3 Phân biệt Flow đã hoàn tất và NIDS thời gian thực	6
2.2 Cơ Chế Tấn Công Brute Force trên Giao Thức FTP và SSH	6
2.2.1 Tấn công Brute Force đối với FTP (Port 21)	6
2.2.2 Tấn công Brute Force đối với SSH (Port 22)	6
2.3 Các Thuật Toán Học Máy Dạng Cây	7

2.3.1	Cây Quyết Định (Decision Tree)	7
2.3.2	Rừng Ngẫu Nhiên (Random Forest)	7
2.3.3	XGBoost (eXtreme Gradient Boosting)	8
2.4	Đánh Giá Mô Hình Trên Dữ Liệu Mất Cân Bằng Nghiêm Trọng	9
2.4.1	Hệ Thống Chi Số Tử Ma Trận Nhầm Lẫn	9
2.4.2	Nghịch Lý Độ Chính Xác (Accuracy Paradox) Trong NIDS	9
2.4.3	Đường Cong Precision-Recall (PR) và Average Precision (AP)	10
3	Tập Dữ Liệu và Định Nghĩa Bài Toán	11
3.1	Tổng Quan Tập Dữ Liệu CICIDS2017 Tuesday	11
3.2	Nguồn Gốc Dữ Liệu và Xác Minh Tính Toàn Vẹn SHA-256	11
3.3	Phục Hồi Dòng Thời Gian 24 Giờ (Timestamp Reconstruction)	12
3.3.1	Quy tắc phục hồi 24 giờ chuẩn mực	12
3.4	Định Nghĩa Bài Toán và Không Gian Nhãn	13
3.5	Quy Trình Làm Sạch Dữ Liệu Thô	13
3.6	Dòng Thời Gian Tấn Công Thực Tế và Phân Bỏ Mẫu	14
4	Phương Pháp và Kiến Trúc Hệ Thống	15
4.1	Kiến Trúc Tổng Thể của Hệ Thống Thực Nghiệm	15
4.2	Chính Sách Quản Lý Đặc Trưng (Feature Schema Policy)	15
4.2.1	Thực nghiệm Bóc tách Cổng dịch vụ (Port Ablation Design)	16
4.3	Thiết Kế Chiến Lược Phân Tách Dữ Liệu	16
4.3.1	Cơ chế Purge và Embargo Chống Rò Rỉ Ranh Giới Thời Gian	16
4.3.2	Chiến Lược Đối Chứng: Phân Tách Ngẫu Nhiên (Random Split)	17
4.4	Quy Trình Tiền Xử Lý Độc Lập Trên Tập Train (Train-Only Preprocessing)	17
4.5	Nguyên Tắc Đóng Băng Mô Hình (Single-Open Test Rule)	18
5	Thiết Kế Thực Nghiệm	19
5.1	Môi Trường Thực Thi Phần Cứng và Phần Mềm	19
5.2	Kiểm Soát Tính Ngẫu Nhiên	19

5.3	Xử Lý Mất Cân Bằng Lớp Trên Tập Huấn Luyện	19
5.4	Thiết Lập Không Gian Tìm Kiếm Siêu Tham Số	20
5.5	Tiêu Chí Lựa Chọn Mô Hình Chiến Thắng (Validation Selection)	21
5.6	Phân Định Rõ Hai Chế Độ Huấn Luyện (Model Regimes)	21
5.6.1	Chế độ 1: Canonical Strict Zero-Shot Regime (Chuẩn Mục Chính) .	21
5.6.2	Chế độ 2: Subtype-Aware / Refit Regime (Case Study Mở Rộng) . .	21
5.7	Đảm Bảo Tính Toàn Vẹn và Khả Năng Tái Lập	22
6	Kết Quả Thực Nghiệm	23
6.1	Tổng Hợp Thống Kê Dữ Liệu Sau Tiền Xử Lý	23
6.2	Kết Quả Đánh Giá và Lựa Chọn Mô Hình Trên Tập Validation	23
6.3	Kết Quả Đánh Giá Tập Test Theo Thời Gian (Primary Benchmark)	25
6.4	Kết Quả Thực Nghiệm Đối Chứng Trên Phân Tách Ngẫu Nhiên	26
6.4.1	Đo lường Định lượng Độ lệch Đánh giá (Optimistic Evaluation Bias)	27
6.5	Kết Quả Thực Nghiệm Bóc Tách Cổng Mạng (Port Ablation)	27
6.6	Phân Tích Khả Năng Giải Thích (Explainability Analysis)	29
6.6.1	Phân Tích Tầm Quan Trọng Đặc Trưng Bằng SHAP	29
6.6.2	Trích Xuất Cấu Trúc Cây Quyết Định	30
6.7	Nghiên Cứu Điển Hình (Case Study): Tác Động Của Giao Thức Refit Trên XGBoost	31
6.7.1	Truy Vết Nguyên Nhân Kỹ Thuật Trong Mã Nguồn	31
6.7.2	Hậu Quả Đối Với Bản Chất Bài Toán Đánh Giá	32
7	Thảo Luận Chuyên Sâu	33
7.1	Tại Sao Bài Toán Phân Tách Theo Thời Gian Lại Khó: Thách Thức Subtype Distribution Shift	33
7.1.1	Sự Khác Biệt Căn Bản Về Cấu Trúc Giao Thức Mạng	33
7.1.2	Bản Chất Của Thuật Toán Học Máy Giám Sát Cổ Điển	34
7.2	Bản Chất Của Phép Chia Ngẫu Nhiên: Vi Phạm Giả Thiết I.I.D và Độ Lệch Đánh Giá	34

7.2.1	Vi Phạm Giả Thiết Độc Lập và Phân Phối Đồng Nhất (I.I.D Violation)	34
7.2.2	Cơ Chế Nội Suy Thay Vì Khái Quát Hóa	35
7.3	Bài Học Thực Tiễn MLOps và Quản Trị Ranh Giới Dữ Liệu Trong An Ninh Mạng	35
7.3.1	Hiểm Họa Từ Các Hành Vi Mặc Định Của Thư Viện Học Máy . . .	35
7.3.2	Thiết Lập Cơ Chế Khóa Cấu Hình Bất Biến (Immutable Audit Markers)	36
7.3.3	Quy Chuẩn 5 Bước Cho Đánh Giá NIDS Bằng Học Máy	36
8	Giới Hạn và Đánh Giá Tính Hợp Lệ	38
8.1	Tính Hợp Lệ Bên Trong (Internal Validity)	38
8.2	Tính Hợp Lệ Khái Niệm (Construct Validity)	39
8.3	Tính Hợp Lệ Bên Ngoài (External Validity)	39
8.4	Tính Hợp Lệ Kết Luận Thống Kê (Statistical Conclusion Validity)	40
9	Kết Luận và Hướng Phát Triển	41
9.1	Tổng Kết Nghiên Cứu và Câu Trả Lời Cho Các Câu Hỏi Nghiên Cứu . . .	41
9.2	Đóng Góp Khoa Học và Ý Nghĩa Thực Tiễn	42
9.3	Hướng Nghiên Cứu Tiếp Theo	42
	Tài Liệu Tham Khảo	44
A	Hướng Dẫn Cài Đặt và Tái Lập Thực Nghiệm	45
A.1	Yêu Cầu Môi Trường và Cài Đặt Phụ Thuộc	45
A.2	Chuẩn Bị Dữ Liệu và Phân Tách	45
A.3	Chạy Thực Nghiệm và Kiểm Thử Đóng Băng	46
B	Không Gian Siêu Tham Số và Cấu Hình Tối Ưu	47
C	Danh Mục Đầy Đủ Các Đặc Trưng Mạng	48
D	Quy Tắc Rẽ Nhánh Của Cây Quyết Định	52

DANH SÁCH BẢNG

3.1	Quy tắc ánh xạ nhãn bài toán phân loại nhị phân phát hiện tấn công dò quét mật khẩu.	13
3.2	Thống kê số lượng mẫu và phân bố nhãn theo chiến lược Temporal Split v1.	14
4.1	Chính sách kiểm soát không gian đặc trưng và danh mục đặc trưng hằng số bị loại bỏ.	16
6.1	Kết quả đánh giá và lựa chọn cấu hình mô hình tối ưu trên tập Validation (Mốc 10:02 – 14:28).	24
6.2	Hiệu năng đối chuẩn 12 tổ hợp trên tập Test sau khi đã đóng băng mô hình.	25
6.3	Độ lệch hiệu năng ($\Delta F1$ -Score) giữa Phân tách Ngẫu nhiên và Phân tách Thời gian trên tập Validation.	27
6.4	Thực nghiệm Bóc tách Cổng mạng (Port Ablation) trên tập Validation phân tách theo thời gian.	28
6.5	Top 10 đặc trưng mạng có mức độ đóng góp phân loại lớn nhất theo SHAP TreeExplainer trên tập Validation.	29
6.6	Đối chiếu hiệu năng của XGBoost giữa Chế độ Zero-Shot Chuẩn mực và Chế độ Tiếp xúc Validation (Refit).	32
8.1	Tổng hợp các mối đe dọa đến tính hợp lệ của nghiên cứu và giải pháp kiểm soát.	38
B.1	Chi tiết tham số tối ưu của 12 mô hình được lựa chọn trên tập Validation.	47

DANH SÁCH HÌNH VẼ

6.1	Ma trận nhầm lẫn chi tiết của các mô hình trên tập kiểm thử phân tách theo thời gian, thể hiện trực quan sự sụp đổ của True Positive đối với biến thể tấn công SSH.	26
6.2	Đối chiếu hiệu năng giữa Phân tách Ngẫu nhiên và Phân tách Thời gian, trực quan hóa mức độ thổi phồng hiệu năng (Optimistic Bias) do rò rỉ phân phối phiên kết nối.	27
6.3	Đường cong ROC và Precision-Recall đối chiếu giữa các mô hình và kịch bản thực nghiệm, phản ánh sự biến thiên diện tích dưới đường cong khi có và không có đặc trưng cổng mạng.	28
6.4	Biểu đồ phân bố giá trị SHAP (SHAP Summary Plot) của Top các đặc trưng quan trọng trên 500 mẫu kiểm định.	30
6.5	Cấu trúc 3 tầng đầu tiên của Cây Quyết Định minh họa ngưỡng rẽ nhánh ưu tiên tại <code>Destination Port ≤ 21.5</code>	31

DANH MỤC KÝ HIỆU VÀ CHỮ VIẾT TẮT

Ký hiệu / Viết tắt	Ý nghĩa giải thích đầy đủ
AP	Average Precision (Độ chính xác trung bình tích hợp theo diện tích dưới đường cong PR)
CIC	Canadian Institute for Cybersecurity (Viện An ninh mạng Canada)
CSV	Comma-Separated Values (Tập định dạng giá trị ngăn cách bằng dấu phẩy)
CV	Cross-Validation (Kiểm định chéo)
DoD	Definition of Done (Tiêu chuẩn hoàn thành công việc)
DT	Decision Tree (Cây quyết định)
EDA	Exploratory Data Analysis (Khám phá và phân tích dữ liệu ban đầu)
FN	False Negative (Số lượng mẫu tấn công bị phân loại nhầm là bình thường)
FP	False Positive (Số lượng mẫu bình thường bị cảnh báo nhầm là tấn công)
FPR	False Positive Rate (Tỷ lệ báo động giả trên tổng số lưu lượng bình thường)
FTP	File Transfer Protocol (Giao thức truyền tải tệp tin, Cổng mặc định 21)
IAT	Inter-Arrival Time (Khoảng thời gian trễ giữa các gói tin liên tiếp trong một flow)
IDS	Intrusion Detection System (Hệ thống phát hiện xâm nhập)
IP	Internet Protocol (Giao thức mạng Internet)
ML	Machine Learning (Học máy)
MLOps	Machine Learning Operations (Quy trình vận hành và triển khai hệ thống học máy)
NIDS	Network Intrusion Detection System (Hệ thống phát hiện xâm nhập mạng)
PCAP	Packet Capture (Tập lưu trữ bản ghi lưu lượng gói tin mạng thô)
PR	Precision-Recall (Đường cong tương quan giữa Độ chính xác và Độ thu hồi)
RF	Random Forest (Rừng ngẫu nhiên)
ROC	Receiver Operating Characteristic (Đường cong đặc trưng hoạt động của bộ thu)
ROCAUC	Area Under the Receiver Operating Characteristic Curve (Diện tích dưới đường ROC)
RQ	Research Question (Câu hỏi nghiên cứu)
SHA-256	Secure Hash Algorithm 256-bit (Thuật toán mã hóa băm an toàn 256-bit)
SHAP	SHapley Additive exPlanations (Phương pháp giải thích dự đoán dựa trên lý thuyết trò chơi Shapley)

Ký hiệu / Viết tắt	Ý nghĩa giải thích đầy đủ
SSH	Secure Shell (Giao thức truyền thông an toàn và điều khiển từ xa, Cổng mặc định 22)
TCP	Transmission Control Protocol (Giao thức điều khiển truyền vận)
TN	True Negative (Số lượng mẫu bình thường được phân loại đúng)
TP	True Positive (Số lượng mẫu tấn công được phát hiện chính xác)
XGB	eXtreme Gradient Boosting (Thuật toán tăng cường độ dốc cực đại)

Chương 1

GIỚI THIỆU VÀ ĐẶT VẤN ĐỀ

1.1 Bối Cảnh An Ninh Mạng và Nguy Cơ Tấn Công Brute Force

Trong kỷ nguyên chuyển đổi số và phát triển bùng nổ của hạ tầng điện toán đám mây, an toàn an ninh thông tin đã trở thành yêu cầu sống còn đối với các tổ chức và doanh nghiệp. Trong số các hình thức tấn công mạng phổ biến, tấn công dò quét và vét cạn thông tin xác thực (Brute Force / Dictionary Attacks) nhắm vào các giao thức quản trị và truyền tệp từ xa như SSH (Secure Shell - Cổng 22) và FTP (File Transfer Protocol - Cổng 21) vẫn là một trong những mối đe dọa thường trực nhất. Bằng cách tự động hóa hàng nghìn đến hàng triệu lượt thử kết hợp tên người dùng và mật khẩu, kẻ tấn công có thể chiếm đoạt quyền điều khiển máy chủ nội bộ, từ đó tạo bàn đạp để leo thang đặc quyền và phát tán mã độc tổng tiền trong toàn bộ hệ thống mạng.

Các hệ thống phát hiện xâm nhập mạng truyền thống (Signature-based NIDS) như Snort hay Suricata hoạt động dựa trên việc đối khớp các mẫu chuỗi nhị phân (signatures) hoặc các quy tắc ngưỡng tần suất tĩnh (threshold rules). Mặc dù có ưu điểm về tốc độ và tỷ lệ báo động giả thấp đối với các biến thể tấn công đã biết, cách tiếp cận này bộc lộ những hạn chế cố hữu:

1. Không có khả năng phát hiện các biến thể tấn công mới hoặc các công cụ quét mật khẩu có cơ chế làm chậm nhịp gõ (low-and-slow) nhằm lách qua các ngưỡng cảnh báo cố định.
2. Chi phí bảo trì, cập nhật bộ luật thủ công rất lớn khi mạng lưới mở rộng.
3. Bất lực trước các giao thức truyền thông mã hóa tầng ứng dụng như SSH, nơi nội dung gói tin payload hoàn toàn bị xáo trộn và bảo vệ bằng mật mã.

1.2 Từ Signature-based sang Học Máy trong Flow-based NIDS

Để khắc phục các nhược điểm trên, cộng đồng nghiên cứu đã hướng sự chú ý mạnh mẽ sang các phương pháp Học máy (Machine Learning - ML). Thay vì phân tích sâu vào nội dung gói tin (Deep Packet Inspection - DPI) vốn tốn kém tài nguyên tính toán và bị cản trở bởi mã

hóa, hướng tiếp cận dựa trên luồng mạng (Flow-based Inspection) chỉ trích xuất các đặc trưng thống kê tổng hợp của cả phiên truyền thông như: tổng thời lượng phiên (Flow Duration), số lượng gói tin hai chiều, kích thước gói tin trung bình và phương sai, khoảng thời gian trễ giữa các gói tin liên tiếp (Inter-Arrival Time - IAT) cũng như số lượng các cờ điều khiển TCP.

Các thuật toán học máy giám sát, đặc biệt là các mô hình dựa trên cây quyết định và học kết hợp (Decision Tree, Random Forest, XGBoost), được kỳ vọng sẽ tự động trích xuất các mẫu hành vi bất thường đặc trưng của lưu lượng tấn công Brute Force mà không cần can thiệp giải mã dữ liệu người dùng.

1.3 Vấn Đề Khoa Học: Đánh Giá Lạc Quan và Thách Thức Thời Gian

Mặc dù có hàng nghìn công trình nghiên cứu về ML-NIDS được công bố hàng năm, việc triển khai thực tế các mô hình này trong các Trung tâm điều hành an ninh mạng (SOC) vẫn gặp phải rào cản rất lớn. Như Sommer và Paxson [1] đã cảnh báo trong công trình kinh điển *Outside the Closed World*, việc ứng dụng học máy trong an ninh mạng có sự khác biệt căn bản so với các lĩnh vực như xử lý ngôn ngữ tự nhiên hay thị giác máy tính: môi trường mạng luôn biến động, dữ liệu có tính chất chuỗi thời gian liên tục và kẻ tấn công luôn chủ động thay đổi hành vi để né tránh.

Đặc biệt, công trình nghiên cứu gần đây của Arp và cộng sự [2] trên hội nghị an ninh hàng đầu USENIX Security đã chỉ ra hàng loạt ”cạm bẫy” (pitfalls) nghiêm trọng đang tồn tại phổ biến trong các nghiên cứu an ninh mạng ứng dụng học máy. Trong đó, sai lầm phổ biến nhất là **Độ lệch đánh giá quá lạc quan (Optimistic Evaluation Bias)** bắt nguồn từ việc sử dụng chiến lược **Phân chia dữ liệu ngẫu nhiên (Random Split)**.

Khi áp dụng phương pháp phân chia ngẫu nhiên trên tập dữ liệu lưu lượng mạng như CICIDS2017 [3]:

- Toàn bộ các flow thuộc cùng một chiến dịch tấn công (phát sinh từ cùng một công cụ dò quét, cùng địa chỉ IP nguồn, cùng cấu hình nhíp gõ) bị xé nhỏ và phân bổ đều vào cả tập Huấn luyện (Train), tập Kiểm định (Validation) và tập Kiểm thử (Test).
- Việc này vi phạm nghiêm trọng giả thiết các quan sát độc lập và phân phối đồng nhất (*i.i.d.*) trong học máy.
- Hệ quả là bài toán phân loại tổng quát hóa bị biến tướng thành bài toán ”nội suy” hoặc ”học thuộc lòng” đặc trưng của một chiến dịch cụ thể. Các mô hình dễ dàng đạt điểm số F1-Score > 99%, nhưng khi đối mặt với một chiến dịch tấn công mới diễn ra trong tương lai, hiệu năng lập tức sụp đổ.

1.4 Mục Tiêu Nghiên Cứu và Câu Hỏi Nghiên Cứu (RQs)

Bài tập lớn này không hướng tới mục tiêu ”chạy đua điểm số” bằng cách sao chép các giao thức đánh giá ngẫu nhiên truyền thống. Thay vào đó, mục tiêu cốt lõi của nghiên cứu là **xây dựng một quy trình thực nghiệm chuẩn mực, minh bạch, kiểm soát chặt chẽ rò rỉ dữ liệu theo thời gian thực (Temporal Leakage Prevention)** trên tập dữ liệu CICIDS2017 Tuesday, từ đó bóc tách bản chất thực sự của các mô hình học máy khi đối mặt với các dạng tấn công dò quét mật khẩu chưa từng thấy.

Đề tài tập trung giải quyết 4 Câu hỏi nghiên cứu (Research Questions - RQ) sau:

- RQ1:** (*Hiệu năng Zero-Shot Subtype Transfer theo thời gian*) Khi mô hình học máy dạng cây chỉ được huấn luyện trên dữ liệu quá khứ chứa một dạng tấn công Brute Force (FTP-Patator), mô hình có khả năng tổng quát hóa để phát hiện dạng tấn công Brute Force mới (SSH-Patator) xuất hiện trong tương lai trên cùng một hệ thống mạng hay không?
- RQ2:** (*Độ lệch đánh giá của phép chia ngẫu nhiên*) Phép chia ngẫu nhiên (Random Split) tạo ra sự thổi phồng kết quả (Optimistic Bias) ở mức độ định lượng bao nhiêu so với phép chia phân tách theo thứ tự thời gian (Time-based Split)?
- RQ3:** (*Vai trò của cổng dịch vụ và các đặc trưng hành vi*) Cổng dịch vụ đích (Destination Port) đóng vai trò như thế nào trong quyết định của mô hình? Khi loại bỏ cổng mạng (Port Ablation), các đặc trưng thống kê hành vi gói tin (Packet lengths, Flow IAT, Flags) có đủ để nhận diện hành vi tấn công hay không?
- RQ4:** (*Tác động của giao thức huấn luyện lại - Refit Protocol Impact*) Việc vô tình cho phép mô hình tiếp xúc với dữ liệu của tập Validation (thông qua cơ chế refit mặc định của các thư viện tự động) làm thay đổi bản chất bài toán đánh giá NIDS từ Zero-Shot sang Supervised Learning như thế nào?

1.5 Đóng Góp của Đề Tài

Các đóng góp cụ thể của đề tài bao gồm:

1. **Xác lập bộ quy chuẩn thực nghiệm nghiêm ngặt (Canonical Protocol):** Thực hiện tiền xử lý và phục hồi dòng thời gian 24h dựa trên phân tích EDA; áp dụng kỹ thuật làm sạch bảo thủ Purge ($q = 60s$) và Embargo ($g = 120s$) loại bỏ 7,632 dòng ranh giới; thiết lập bài toán Zero-Shot Subtype Transfer tự nhiên trên CICIDS2017 Tuesday.

2. **Đánh giá trung thực và khách quan 3 mô hình học máy dạng cây:** Đối chuẩn Decision Tree, Random Forest và XGBoost qua 12 tổ hợp thực nghiệm (3 mô hình $\times$ 2 chiến lược chia $\times$ 2 kích bản cổng). Ghi nhận minh bạch sự sụp đổ của mô hình trên tập Test theo thời gian ($F1\text{-Score} \leq 0.0037$, bắt được 0.19% tấn công SSH).
3. **Bóc tách cơ chế ra quyết định thông qua XAI:** Sử dụng SHAP TreeExplainer và phân tích cấu trúc cây quyết định để chứng minh hiện tượng mô hình học vệt cổng dịch vụ (`Destination Port` chiếm giá trị đóng góp áp đảo 0.1237).
4. **Phát hiện và cảnh báo case study MLOps thực tế:** Phân tích chi tiết trường hợp cờ `refit=True` của thư viện scikit-learn vô tình gây rò rỉ dữ liệu tập Validation, làm sai lệch F1 từ 0.0 lên 0.9912, cung cấp bài học thực tiễn đắt giá cho cộng đồng kỹ thuật.
5. **Mã nguồn và báo cáo có tính tái lập tuyệt đối:** Toàn bộ số liệu trong báo cáo được truy xuất tự động từ các artifact đã đóng băng, đi kèm mã băm SHA-256 xác minh (hướng dẫn tái lập thực nghiệm và kiểm tra bộ test suite được cung cấp tại Phụ lục A).

1.6 Cấu Trúc của Báo Cáo

Báo cáo được tổ chức thành 9 chương:

- **Chương 1:** Giới thiệu bối cảnh, vấn đề khoa học, mục tiêu và 4 câu hỏi nghiên cứu.
- **Chương 2:** Cơ sở lý thuyết về lưu lượng mạng flow, tấn công Brute Force, 3 thuật toán học máy dạng cây và hệ thống chỉ số đánh giá mất cân bằng lớp.
- **Chương 3:** Chi tiết tập dữ liệu CICIDS2017 Tuesday, kiểm tra toàn vẹn băm, phục hồi đồng hồ 24h và làm sạch dữ liệu.
- **Chương 4:** Phương pháp đề xuất, chính sách đặc trưng, kỹ thuật Purge/Embargo và nguyên tắc đóng băng mô hình.
- **Chương 5:** Thiết kế thực nghiệm, không gian tìm kiếm siêu tham số và hàm mục tiêu lựa chọn mô hình trên tập Validation.
- **Chương 6:** Báo cáo chi tiết các kết quả định lượng thu được từ 12 tổ hợp thực nghiệm, phân tích ma trận nhầm lẫn, đường cong PR và giải thích SHAP.
- **Chương 7:** Thảo luận chuyên sâu về thất bại của Zero-shot Transfer, nguyên nhân của Optimistic Bias và bài học MLOps về cờ refit.
- **Chương 8:** Phân tích các giới hạn của nghiên cứu theo 4 khía cạnh Threats to Validity.
- **Chương 9:** Kết luận, trả lời trực tiếp RQ1–RQ4 và đề xuất hướng nghiên cứu tiếp theo.

Chương 2

CƠ SỞ LÝ THUYẾT

2.1 Bản Chất Lưu Lượng Mạng và Cơ Chế Flow-Based Inspection

2.1.1 Khái niệm Luồng Mạng (IP Network Flow)

Trong kiến trúc mạng TCP/IP, một luồng mạng (Network Flow) được định nghĩa theo chuẩn RFC 7011 (IPFIX) là một chuỗi các gói tin (packets) truyền qua một điểm quan sát trên mạng trong một khoảng thời gian nhất định và chia sẻ chung một bộ thuộc tính nhận dạng đặc trưng, thường được gọi là **5-Tuple**:

$$\text{Flow 5-Tuple} = \langle \text{Source IP, Destination IP, Source Port, Destination Port, Protocol} \rangle \quad (2.1)$$

2.1.2 Cơ chế sinh đặc trưng của CICFlowMeter

Công cụ CICFlowMeter [3] thực hiện tổng hợp các gói tin thuộc cùng một 5-Tuple theo cả hai hướng truyền thông (Forward - từ client đến server, và Backward - từ server về client) để tạo thành một **Bi-directional Flow**. Một flow được coi là kết thúc khi xảy ra một trong các điều kiện sau:

1. Xuất hiện cờ điều khiển đóng kết nối TCP (FIN hoặc RST).
2. Khoảng thời gian không có gói tin nào mới vượt quá ngưỡng thời gian chờ không hoạt động (Inactivity Timeout, mặc định thường là 15 đến 60 giây).
3. Tổng thời lượng của flow vượt quá thời gian tối đa cho phép (Flow Timeout).

Sau khi flow đóng, CICFlowMeter tính toán hơn 80 chỉ số thống kê tổng hợp mô tả toàn bộ vòng đời của flow, bao gồm thời lượng phiên truyền, thống kê kích thước gói tin (min, max, mean, std), khoảng thời gian trễ giữa các gói tin (Flow IAT, Fwd IAT, Bwd IAT), số lượng các cờ TCP (SYN, ACK, PSH, URG, FIN) và kích thước cửa sổ nhận ban đầu (Init_Win_bytes).

2.1.3 Phân biệt Flow đã hoàn tất và NIDS thời gian thực

Một điểm cốt lõi cần khẳng định về mặt lý thuyết: vì toàn bộ các đặc trưng thống kê nói trên chỉ được tính toán đầy đủ **sau khi flow đã kết thúc hoàn toàn**, các mô hình học máy được xây dựng trên dữ liệu này hoạt động ở cơ chế **Phân loại Flow đã hoàn tất (Completed-Flow Classification / Post-mortem Analysis)**.

Hệ thống này **không phải** là hệ thống phát hiện xâm nhập thời gian thực ở mức gói tin (Real-time Packet-level IDS). Mô hình không thể can thiệp ngăn chặn tấn công ngay ở những gói tin bắt tay đầu tiên và không đo lường độ trễ phát hiện (Detection Latency) theo mili-giây.

2.2 Cơ Chế Tấn Công Brute Force trên Giao Thức FTP và SSH

2.2.1 Tấn công Brute Force đối với FTP (Port 21)

FTP (File Transfer Protocol) là giao thức truyền tệp hoạt động trên kênh văn bản rõ (plain-text) ở tầng ứng dụng:

- Quá trình xác thực diễn ra thông qua các cặp lệnh `USER` và `PASS`.
- Máy chủ phản hồi bằng mã trạng thái `230 User logged in` (thành công) hoặc `530 Login incorrect` (thất bại).
- Khi công cụ Patator (`ftp_patator`) thực hiện tấn công brute force, nó thiết lập liên tục các kết nối TCP mới, gửi lệnh thử mật khẩu và đóng kết nối ngay khi nhận mã 530.
- **Đặc trưng thống kê:** Vì là văn bản rõ, các gói tin yêu cầu và phản hồi có kích thước rất ngắn và cố định. Lưu lượng hướng đi (Fwd) thường có độ lệch chuẩn kích thước gói tin rất nhỏ.

2.2.2 Tấn công Brute Force đối với SSH (Port 22)

SSH (Secure Shell) là giao thức truyền thông an toàn cung cấp kênh xác thực và điều khiển được mã hóa:

- Trước khi quá trình gửi thông tin xác thực diễn ra, client và server bắt buộc phải trải qua pha bắt tay mật mã phức tạp: trao đổi phiên bản giao thức (SSH-2.0-OpenSSH), thương lượng thuật toán mã hóa đối xứng, trao đổi khóa Diffie-Hellman và xác thực khóa công khai của host.
- Quá trình xác thực mật khẩu diễn ra hoàn toàn bên trong kênh đã được mã hóa bằng thuật toán đối xứng (như AES-GCM hoặc ChaCha20-Poly1305).

- **Đặc trưng thống kê:** Pha trao đổi khóa mã hóa làm phát sinh các gói tin có kích thước lớn hơn đáng kể so với FTP. Cấu trúc bắt tay phức tạp làm cho các chỉ số về kích thước gói tin trung bình (`Packet Length Mean`) và thời gian trễ giữa các gói tin (`Flow IAT`) của SSH có phân phối thống kê khác biệt căn bản so với FTP.

2.3 Các Thuật Toán Học Máy Dạng Cây

2.3.1 Cây Quyết Định (Decision Tree)

Cây quyết định phân loại (Classification Decision Tree [4]) phân chia không gian đặc trưng thành các vùng siêu hình hộp rời rạc thông qua một tập hợp các quy tắc rẽ nhánh dạng bậc thang ($x_j \leq \theta$).

Tại mỗi nút phân chia, thuật toán tìm kiếm đặc trưng j và ngưỡng θ tối ưu nhằm tối đa hóa mức giảm độ vẩn đục (Impurity Reduction). Chỉ số vẩn đục phổ biến là **Gini Impurity**:

$$I_G(p) = 1 - \sum_{k=0}^1 p_k^2 \quad (2.2)$$

hoặc **Entropy (Information Gain)**:

$$H(p) = - \sum_{k=0}^1 p_k \log_2(p_k) \quad (2.3)$$

trong đó p_k là tỷ lệ mẫu thuộc lớp k tại nút đang xét. Mức giảm độ vẩn đục khi phân chia tập S thành S_L và S_R được tính bằng:

$$\Delta I(S, j, \theta) = I(S) - \left(\frac{|S_L|}{|S|} I(S_L) + \frac{|S_R|}{|S|} I(S_R) \right) \quad (2.4)$$

Ưu điểm nổi bật của Decision Tree là tính minh bạch và khả năng trực quan hóa cấu trúc rẽ nhánh, giúp giải thích trực tiếp logic phân loại. Tuy nhiên, Decision Tree đơn lẻ có phương sai rất cao và dễ bị quá khớp (overfitting) với các đặc trưng cục bộ.

2.3.2 Rừng Ngẫu Nhiên (Random Forest)

Random Forest [5] là một phương pháp học kết hợp (Ensemble Learning) dựa trên kỹ thuật đóng bao (Bootstrap Aggregating - Bagging). Mô hình xây dựng một tập hợp gồm B cây quyết định độc lập:

$$\hat{y} = \text{mode} \{T_1(\mathbf{x}), T_2(\mathbf{x}), \dots, T_B(\mathbf{x})\} \quad (2.5)$$

hoặc tính xác suất trung bình:

$$P(y = 1|\mathbf{x}) = \frac{1}{B} \sum_{b=1}^B P_b(y = 1|\mathbf{x}) \quad (2.6)$$

Hai cơ chế ngẫu nhiên hóa cốt lõi của Random Forest giúp giảm thiểu phương sai mà không làm tăng độ chệch (bias):

1. **Bootstrap Sampling:** Mỗi cây được huấn luyện trên một tập dữ liệu con được rút mẫu có hoàn lại từ tập huấn luyện gốc với kích thước bằng N .
2. **Random Feature Subspace:** Tại mỗi nút rẽ nhánh, thay vì tìm kiếm trên toàn bộ D đặc trưng, thuật toán chỉ chọn ngẫu nhiên một tập con gồm $m \approx \sqrt{D}$ đặc trưng để chọn ra điểm phân chia tốt nhất. Cơ chế này giúp giải tương quan (decorrelate) giữa các cây trong rừng.

2.3.3 XGBoost (eXtreme Gradient Boosting)

XGBoost [6] là một thuật toán nâng cao thuộc họ Gradient Boosting. Khác với Bagging xây dựng các cây độc lập song song, Boosting xây dựng các cây quyết định tuần tự, trong đó mỗi cây mới $f_t(\mathbf{x})$ được tối ưu để bù đắp sai số (residuals) của tổ hợp các cây trước đó:

$$\hat{y}_i^{(t)} = \hat{y}_i^{(t-1)} + f_t(\mathbf{x}_i) \quad (2.7)$$

Hàm mục tiêu được tối thiểu hóa tại bước t bao gồm hàm mất mát khả vi (differentiable loss function) và số hạng chính quy hóa (regularization term) để kiểm soát độ phức tạp của cây:

$$\mathcal{L}^{(t)} = \sum_{i=1}^n l(y_i, \hat{y}_i^{(t-1)} + f_t(\mathbf{x}_i)) + \Omega(f_t) \quad (2.8)$$

với số hạng phạt phức tạp:

$$\Omega(f) = \gamma T + \frac{1}{2} \lambda \sum_{j=1}^T w_j^2 \quad (2.9)$$

trong đó T là số lượng lá, w_j là trọng số tại lá j , γ là ngưỡng phạt tối thiểu để tạo lá mới và λ là hệ số chính quy hóa L2.

XGBoost áp dụng xấp xỉ Taylor bậc hai (Second-order Taylor Expansion) cho hàm mục tiêu:

$$\mathcal{L}^{(t)} \approx \sum_{i=1}^n \left[l(y_i, \hat{y}_i^{(t-1)}) + g_i f_t(\mathbf{x}_i) + \frac{1}{2} h_i f_t^2(\mathbf{x}_i) \right] + \Omega(f_t) \quad (2.10)$$

trong đó $g_i = \partial_{\hat{y}^{(t-1)}} l(y_i, \hat{y}^{(t-1)})$ là gradient bậc một và $h_i = \partial_{\hat{y}^{(t-1)}}^2 l(y_i, \hat{y}^{(t-1)})$ là Hessian bậc hai. Ngoài ra, việc sử dụng thuật toán xấp xỉ Histogram (`tree_method='hist'`) giúp tăng tốc độ huấn luyện trên dữ liệu lớn mà vẫn duy trì độ chính xác cao.

2.4 Đánh Giá Mô Hình Trên Dữ Liệu Mất Cân Bằng Nghiêm Trọng

2.4.1 Hệ Thống Chỉ Số Từ Ma Trận Nhầm Lẫn

Trong bài toán phát hiện xâm nhập mạng, lớp tấn công (`Attack`, gán nhãn 1) thường chỉ chiếm tỷ lệ nhỏ ($< 5\%$) so với lưu lượng bình thường (`Normal`, gán nhãn 0). Ma trận nhầm lẫn (Confusion Matrix) gồm 4 đại lượng:

- **True Positive (TP):** Số flow tấn công được phát hiện chính xác.
- **False Positive (FP):** Số flow bình thường bị cảnh báo nhầm là tấn công (Báo động giả).
- **False Negative (FN):** Số flow tấn công bị bỏ lọt (Nguy hiểm nhất trong an ninh).
- **True Negative (TN):** Số flow bình thường được phân loại đúng.

Các chỉ số phái sinh chuẩn:

$$\text{Precision} = \frac{TP}{TP + FP} \quad (2.11)$$

$$\text{Recall (TPR)} = \frac{TP}{TP + FN} \quad (2.12)$$

$$\text{False Positive Rate (FPR)} = \frac{FP}{FP + TN} \quad (2.13)$$

$$\text{F1-Score} = 2 \cdot \frac{\text{Precision} \cdot \text{Recall}}{\text{Precision} + \text{Recall}} = \frac{2TP}{2TP + FP + FN} \quad (2.14)$$

2.4.2 Nghịch Lý Độ Chính Xác (Accuracy Paradox) Trong NIDS

Chỉ số Accuracy tổng thể:

$$\text{Accuracy} = \frac{TP + TN}{TP + TN + FP + FN} \quad (2.15)$$

rất nguy hiểm và hoàn toàn gây hiểu lầm trong an ninh mạng. Giả sử tập kiểm thử có 97.4% mẫu bình thường và 2.6% mẫu tấn công (như tập Test CICIDS2017 Tuesday). Một bộ phân loại tầm thường (trivial classifier) luôn dự đoán mọi flow là bình thường ($TP = 0, FP = 0$)

sẽ đạt ngay **Accuracy = 97.4%** mặc dù hoàn toàn bất lực trong việc bảo vệ hệ thống (**Recall = 0.0%**). Do đó, F1-Score và Precision-Recall Curve là tiêu chuẩn đánh giá bắt buộc.

2.4.3 Đường Cong Precision-Recall (PR) và Average Precision (AP)

Như Davis và Goadrich [7] đã chứng minh, trên các tập dữ liệu mất cân bằng lớp cực đoan, đường cong ROC (Receiver Operating Characteristic) có thể phản ánh một cái nhìn sai lệch quá mức lạc quan vì đại lượng TN trong mẫu số của FPR quá lớn làm FPR luôn giữ ở mức rất thấp.

Đường cong Precision-Recall biểu diễn mối quan hệ đánh đổi giữa Precision và Recall khi thay đổi ngưỡng phân loại $\tau \in [0, 1]$. Đại lượng **Average Precision (AP)** tích phân diện tích dưới đường cong PR không suy biến:

$$AP = \sum_n (R_n - R_{n-1}) P_n \quad (2.16)$$

trong đó P_n và R_n là Precision và Recall tại ngưỡng thứ n . AP là chỉ số phản ánh trung thực nhất năng lực phân tách của mô hình trên lớp thiểu số.

Chương 3

TẬP DỮ LIỆU VÀ ĐỊNH NGHĨA BÀI TOÁN

3.1 Tổng Quan Tập Dữ Liệu CICIDS2017 Tuesday

Tập dữ liệu CICIDS2017 [3] được xây dựng bởi Viện An ninh mạng Canada (Canadian Institute for Cybersecurity - CIC), Đại học New Brunswick (UNB). Đây là một trong những bộ dữ liệu chuẩn mực và được sử dụng rộng rãi nhất để nghiên cứu và đánh giá các hệ thống phát hiện xâm nhập mạng thế hệ mới.

Tập dữ liệu ghi lại toàn bộ lưu lượng mạng trong 5 ngày làm việc liên tiếp (từ thứ Hai ngày 03/07/2017 đến thứ Sáu ngày 07/07/2017) trên một hạ tầng mạng mô phỏng gồm mạng nạn nhân (Victim Network) và mạng tấn công bên ngoài (Attacker Network). Trong đó, ngày thứ Ba (Tuesday, 04/07/2017) được dành riêng để thực hiện các kịch bản tấn công vét cạn mật khẩu (Brute Force):

- **Tấn công buổi sáng:** FTP-Patator thực hiện dò quét mật khẩu dịch vụ FTP (Cổng 21) từ 09:20 đến 10:20.
- **Tấn công buổi chiều:** SSH-Patator thực hiện dò quét mật khẩu dịch vụ SSH (Cổng 22) từ 14:00 đến 15:00.

3.2 Nguồn Gốc Dữ Liệu và Xác Minh Tính Toàn Vẹn SHA-256

Dữ liệu thô được sử dụng trong nghiên cứu này là tệp CSV trích xuất chính thức từ gói `GeneratedLabelledFlows.zip` của UNB:

- **Đường dẫn:** `data/raw/Tuesday-WorkingHours.pcap_ISCX.csv`
- **Mã băm SHA-256 đã xác minh:**

`ae9c88e10c41a8eb1ff454ae98bc513454925097d0b0b57180f94e79de445815`

- **Tổng số dòng thô ban đầu:** 445,909 bản ghi flow (tương ứng 445,910 dòng trên đĩa tính cả 1 dòng tiêu đề).

Việc lưu trữ và kiểm tra mã băm SHA-256 đảm bảo tính toàn vẹn tuyệt đối của dữ liệu đầu vào, cho phép bất kỳ nhà nghiên cứu nào trên thế giới cũng có thể kiểm chứng độc lập trên cùng một tệp dữ liệu nguồn.

3.3 Phục Hồi Dòng Thời Gian 24 Giờ (Timestamp Reconstruction)

Trong quá trình Khám phá Dữ liệu (Exploratory Data Analysis - EDA), chúng tôi phát hiện một lỗi định dạng nghiêm trọng trong tệp CSV gốc do công cụ CICFlowMeter xuất ra:

- Định dạng chuỗi thời gian thô được lưu dưới dạng `dd/MM/yyyy` kết hợp với `h:mm` hoặc `hh:mm`.
- Các giá trị giờ thô quan sát được trong dữ liệu chỉ gồm hai nhóm:

$$\mathcal{H}_{\text{raw}} = \{1, 2, 3, 4, 5, 8, 9, 10, 11, 12\} \quad (3.1)$$

- Các bản ghi diễn ra vào buổi chiều (từ 13:00 đến 17:00) đã bị công cụ xuất nhầm theo định dạng đồng hồ 12 giờ thành 1:00 đến 5:00 mà không hề có hậu tố chỉ định PM.

Nếu phân tích trực tiếp chuỗi thời gian này mà không phục hồi, các flow buổi chiều sẽ bị sắp xếp nhầm thành buổi đêm/sáng sớm (1h - 5h sáng), làm đảo lộn hoàn toàn thứ tự thời gian của các chiến dịch tấn công.

3.3.1 Quy tắc phục hồi 24 giờ chuẩn mực

Quy tắc phục hồi được hiện thực hóa thông qua hàm `reconstruct_timestamp()` tại tệp mã nguồn `scripts/prepare_splits.py`:

$$H_{24h} = \begin{cases} H_{\text{raw}} + 12 & \text{nếu } H_{\text{raw}} \in \{1, 2, 3, 4, 5\} \\ H_{\text{raw}} & \text{nếu } H_{\text{raw}} \in \{8, 9, 10, 11, 12\} \end{cases} \quad (3.2)$$

Nguyên tắc kiểm soát rò rỉ dữ liệu (No-Leakage Policy): Quy tắc phục hồi này được thiết lập độc lập hoàn toàn với nhãn tấn công (Label) và cổng đích (Destination Port), chỉ dựa trên phân tích dòng thời gian của toàn bộ traffic trong ngày Tuesday (thời gian làm việc từ 8:30 sáng đến 17:00 chiều).

3.4 Định Nghĩa Bài Toán và Không Gian Nhãn

Bài tập lớn định nghĩa bài toán phân loại là **Phân loại nhị phân (Binary Classification)** nhằm nhận diện lưu lượng bất thường:

$$y = \begin{cases} 0 & \text{nếu flow là lưu lượng bình thường (BENIGN)} \\ 1 & \text{nếu flow là tấn công Brute Force (FTP-Patator hoặc SSH-Patator)} \end{cases} \quad (3.3)$$

Chi tiết ánh xạ nhãn được trình bày trong Bảng 3.1.

Bảng 3.1: Quy tắc ánh xạ nhãn bài toán phân loại nhị phân phát hiện tấn công dò quét mật khẩu.

Nhãn gốc trong dữ liệu	Nhãn y	Xử lý bài toán	Mô tả bản chất an ninh mạng
BENIGN	0	Lớp thường (Normal)	Lưu lượng mạng của các tác vụ và giao dịch hợp lệ của người dùng nội bộ.
FTP-Patator	1	Lớp tấn công (Attack)	Hành vi dò quét thử mật khẩu liên tục đối với dịch vụ FTP (Cổng đích 21).
SSH-Patator	1	Lớp tấn công (Attack)	Hành vi dò quét thử mật khẩu tự động đối với dịch vụ SSH (Cổng đích 22).

Mặc dù bài toán phân loại chính là nhị phân, thông tin chi tiết về dạng tấn công (Subtype) vẫn được bảo toàn nguyên vẹn trong một cột siêu dữ liệu riêng biệt để phục vụ việc đánh giá khả năng phát hiện chi tiết từng dạng tấn công (Subtype Recall).

3.5 Quy Trình Làm Sạch Dữ Liệu Thô

Tập dữ liệu thô trải qua các bước làm sạch kỹ thuật nghiêm ngặt:

- Loại bỏ flow có thời lượng không hợp lệ:** Loại bỏ 17 bản ghi có Flow Duration ≤ 0 hoặc bị thiếu (NaN).
- Loại bỏ bản ghi trùng lặp tuyệt đối:** Loại bỏ 4 dòng bản ghi trùng lặp hoàn toàn trên tất cả các cột dữ liệu.
- Loại bỏ cột đặc trưng trùng lặp:** Cột Fwd Header Length.1 có giá trị trùng lặp 100% với cột Fwd Header Length được loại bỏ vĩnh viễn khỏi không gian đặc trưng.
- Xử lý giá trị vô cùng:** Có 327 giá trị vô cùng ($\pm\infty$, chủ yếu phát sinh do phép chia cho thời lượng bằng 0 trong các cột Flow Bytes/s và Flow Packets/s) được chuyển đổi thành giá trị NaN để xử lý qua bộ điền giá trị thiếu (Imputer).

Sau khi làm sạch kỹ thuật, tổng số bản ghi hợp lệ đưa vào quy trình phân tách là **445,888 dòng**.

3.6 Dòng Thời Gian Tấn Công Thực Tế và Phân Bố Mẫu

Bảng 3.2 tổng hợp chi tiết số lượng mẫu và phân bố nhãn qua các tập sau khi áp dụng chiến lược phân tách theo thời gian (sẽ được trình bày chi tiết ở Chương 4).

Bảng 3.2: Thống kê số lượng mẫu và phân bố nhãn theo chiến lược Temporal Split v1.

Tập dữ liệu	Tổng số flow	BENIGN	Tấn công	FTP-Patator	SSH-Patator	Tỷ lệ Attack (%)
Train ($e < A$)	90,273	85,139	5,134	5,134	0	5.69%
Validation ($s \geq A + g, e < B$)	203,826	199,522	4,304	2,418	1,886	2.11%
Test ($s \geq B + g$)	144,157	140,425	3,732	0	3,732	2.59%
Purge / Embargo ranh giới	7,632	6,967	665	386	279	8.71%
Tổng số dòng sau làm sạch	445,888	432,053	13,835	7,938	5,897	3.10%

Phân tích dòng thời gian chỉ ra một đặc tính tự nhiên vô cùng thú vị của dữ liệu CICIDS2017 Tuesday:

- **Tập Train** ($e < 10 : 00$): Chứa 85,139 mẫu bình thường và 5,134 mẫu **FTP-Patator**. Hoàn toàn **không có SSH-Patator (0 mẫu)**.
- **Tập Validation** ($10 : 02 \leq s$ và $e < 14 : 30$): Chứa đoạn kết của chiến dịch FTP (2,418 mẫu) và giai đoạn đầu của chiến dịch SSH (1,886 mẫu).
- **Tập Test** ($s \geq 14 : 32$): Chứa 140,425 mẫu bình thường và 3,732 mẫu **SSH-Patator**. Hoàn toàn **không có FTP-Patator (0 mẫu)**.

Đặc tính phân bố này biến việc đánh giá trên tập Test theo thời gian thành một bài toán **Zero-Shot Subtype Transfer** khắt khe và thực tế: mô hình được học duy nhất trên FTP vào buổi sáng, liệu có phát hiện được SSH vào buổi chiều hay không?

Chương 4

PHƯƠNG PHÁP VÀ KIẾN TRÚC HỆ THỐNG

4.1 Kiến Trúc Tổng Thể của Hệ Thống Thực Nghiệm

Nhằm đảm bảo tính khách quan và kiểm soát triệt để mọi rủi ro rò rỉ dữ liệu (Data Leakage), hệ thống nghiên cứu thực nghiệm được thiết kế theo một kiến trúc đường ống (Pipeline Architecture) gồm 5 giai đoạn độc lập:

1. **Giai đoạn 1: Chuẩn bị dữ liệu và Phân tách (Data Splitting):** Áp dụng phục hồi dòng thời gian và thuật toán Purge/Embargo để chia tách dữ liệu thành Train, Validation và Test độc lập.
2. **Giai đoạn 2: Tiền xử lý chỉ học từ tập Train (Train-Only Preprocessing):** Loại bỏ các đặc trưng hằng số và khớp (fit) bộ điền giá trị thiếu (median) duy nhất trên $\mathcal{D}_{\text{train}}$.
3. **Giai đoạn 3: Tinh chỉnh Siêu tham số (Hyperparameter Tuning):** Tìm kiếm cấu hình tối ưu của 3 mô hình cây trên không gian $\mathcal{D}_{\text{train}} \times \mathcal{D}_{\text{val}}$.
4. **Giai đoạn 4: Đóng băng Cấu hình (Model Freeze):** Khóa tham số và cấu hình tốt nhất vào tệp siêu dữ liệu `frozen.json`.
5. **Giai đoạn 5: Mở Kiểm thử một lần duy nhất (Single-Open Test Evaluation):** Đánh giá hiệu năng tổng quát hóa trên $\mathcal{D}_{\text{test}}$ mà không tinh chỉnh lại bất kỳ tham số nào.

4.2 Chính Sách Quản Lý Đặc Trưng (Feature Schema Policy)

Để ngăn chặn các "lối tắt học vẹt" (Shortcut Learning [8]), toàn bộ các trường thông tin định danh và siêu dữ liệu không phản ánh hành vi mạng thuần túy đều bị loại bỏ nghiêm ngặt khỏi không gian đặc trưng:

- **Các trường cấm tuyệt đối:** Flow ID, Source IP, Destination IP, Source Port, Timestamp, Timestamp_fixed, Protocol, TimeBin10, _row_id, index. Việc giữ lại địa chỉ IP hay nhãn thời gian sẽ khiến mô hình ghi nhớ máy chủ tấn công thay vì học mẫu lưu lượng.

Chi tiết chính sách quản lý đặc trưng được trình bày trong Bảng 4.1.

Bảng 4.1: Chính sách kiểm soát không gian đặc trưng và danh mục đặc trưng hằng số bị loại bỏ.

Nhóm đặc trưng	Chi tiết các trường thông tin và quy tắc xử lý
Trường cấm tuyệt đối	Flow ID, Source IP, Destination IP, Source Port, Timestamp, Timestamp_fixed, Protocol, TimeBin10, _row_id, index.
Lý do cấm	Ngăn chặn mô hình học thuộc lòng địa chỉ máy chủ tấn công hoặc ghi nhớ thời điểm diễn ra chiến dịch.
10 Đặc trưng hằng số	Bwd PSH Flags, Fwd URG Flags, Bwd URG Flags, CWE Flag Count, Fwd Avg Bytes/Bulk, Fwd Avg Packets/Bulk, Fwd Avg Bulk Rate, Bwd Avg Bytes/Bulk, Bwd Avg Packets/Bulk, Bwd Avg Bulk Rate.
Cơ chế phát hiện	Toàn bộ giá trị có phương sai bằng 0 trên tập Train ($\mathcal{D}_{\text{train}}$) $\rightarrow$ Loại bỏ đồng bộ trên Val và Test.
Không gian cuối cùng	67 đặc trưng (kịch bản with_port) và 66 đặc trưng (kịch bản without_port).

4.2.1 Thực nghiệm Bóc tách Cổng dịch vụ (Port Ablation Design)

Cổng dịch vụ đích (Destination Port) có giá trị bằng 21 cho giao thức FTP và 22 cho giao thức SSH. Để trả lời câu hỏi nghiên cứu RQ3 xem mô hình có bị phụ thuộc thái quá vào số cổng hay không, chúng tôi thiết kế 2 nhánh không gian đặc trưng song song:

1. **Nhánh có cổng** (with_port, 67 đặc trưng): Bao gồm Destination Port cùng toàn bộ các đặc trưng thống kê hành vi luồng mạng.
2. **Nhánh không có cổng** (without_port, 66 đặc trưng): Loại bỏ hoàn toàn Destination Port, buộc mô hình phải dựa 100% vào các đặc trưng thống kê gói tin (Packet lengths, IAT, Flags, Header lengths).

Danh mục định nghĩa chi tiết của toàn bộ 67 đặc trưng mạng được cung cấp tại Phụ lục C.

4.3 Thiết Kế Chiến Lược Phân Tách Dữ Liệu

4.3.1 Cơ chế Purge và Embargo Chống Rò rỉ Ranh Giới Thời Gian

Trong phân tích chuỗi thời gian mạng, một flow có thời điểm bắt đầu s và thời lượng d (tính bằng micro-giây) sẽ kéo dài qua một khoảng thời gian. Để tính toán thời điểm hoàn tất một

cách bảo thủ, chúng tôi bổ sung thêm một sai số làm tròn lượng tử $q = 60s$:

$$e = s + d + q \quad (4.1)$$

Tại mỗi mốc thời gian cắt T_{cutoff} , nguy cơ rò rỉ thông tin xảy ra khi:

1. **Flow vượt ngang ranh giới (Boundary Crossing):** Flow bắt đầu trước T_{cutoff} nhưng kết thúc sau T_{cutoff} ($s < T_{\text{cutoff}}$ và $e \geq T_{\text{cutoff}}$). Nếu giữ lại, thông tin của tương lai đã rò rỉ vào quá khứ. Giải pháp là **Purge** (loại bỏ hoàn toàn các flow này).
2. **Flow diễn ra ngay sau ranh giới:** Để tránh các ảnh hưởng trễ của các kết nối TCP vừa đóng, một khoảng đệm an toàn (Embargo buffer) $g = 120s$ được áp dụng ngay sau mốc cắt. Mọi flow bắt đầu trong khoảng $[T_{\text{cutoff}}, T_{\text{cutoff}} + g)$ đều bị loại bỏ.

Với hai mốc cắt thời gian được xác định từ trước:

- **Mốc A:** 2017-07-04 10:00:00 (Phân cách Train và Validation)
- **Mốc B:** 2017-07-04 14:30:00 (Phân cách Validation và Test)

Thuật toán Purge và Embargo đã loại bỏ tổng cộng **7,632 dòng** ranh giới không an toàn (xem Bảng 3.2), đảm bảo tính độc lập thời gian tuyệt đối giữa các tập dữ liệu.

4.3.2 Chiến Lược Đối Chứng: Phân Tách Ngẫu Nhiên (Random Split)

Để làm cơ sở đối chứng đo lường hiện tượng Optimistic Evaluation Bias, một bản sao dữ liệu thứ hai được phân chia ngẫu nhiên theo phương pháp phân tầng (Stratified Random Split) với tỷ lệ số lượng mẫu tương ứng: Train (20.6%), Validation (46.5%) và Test (32.9%). Phép chia này xáo trộn toàn bộ các flow mà không màng tới thứ tự thời gian xuất hiện.

4.4 Quy Trình Tiền Xử Lý Độc Lập Trên Tập Train (Train-Only Preprocessing)

Một nguyên tắc cốt tử trong MLOps là **bộ tiền xử lý không được phép nhìn thấy dữ liệu tương lai**. Toàn bộ các bước học tham số tiền xử lý được thực hiện nghiêm ngặt trên tập $\mathcal{D}_{\text{train}}$ theo kịch bản `scripts/preprocess_data.py`:

1. **Loại bỏ đặc trưng hằng số:** Thuật toán kiểm tra phương sai của từng đặc trưng trên $\mathcal{D}_{\text{train}}$. Có 10 đặc trưng có giá trị không đổi (phương sai bằng 0) trên $\mathcal{D}_{\text{train}}$ (bao gồm các cờ hiếm như Bwd PSH Flags, Fwd URG Flags, CWE Flag Count và các trường bulk). Danh sách 10 cột này được lưu lại và áp dụng loại bỏ đồng bộ trên $\mathcal{D}_{\text{val}}$ và $\mathcal{D}_{\text{test}}$.

2. **Điền giá trị thiếu (Missing Imputation):** Khởi tạo `SimpleImputer` với chiến lược trung vị (`strategy='median'`). Giá trị trung vị của từng đặc trưng được tính toán duy nhất trên $\mathcal{D}_{\text{train}}$, sau đó được dùng để điền các giá trị NaN trên cả ba tập $\mathcal{D}_{\text{train}}$, $\mathcal{D}_{\text{val}}$ và $\mathcal{D}_{\text{test}}$.

4.5 Nguyên Tắc Đóng Băng Mô Hình (Single-Open Test Rule)

Để loại trừ hoàn toàn nguy cơ tinh chỉnh siêu tham số lặp đi lặp lại trên tập Test (Test Leakage qua con người), dự án áp dụng quy tắc đóng băng nghiêm ngặt:

- Toàn bộ quá trình thử nghiệm, tuning siêu tham số và lựa chọn mô hình chiến thắng được thực hiện hoàn toàn trên tập $\mathcal{D}_{\text{train}}$ và $\mathcal{D}_{\text{val}}$.
- Cấu hình tốt nhất sau đó được xuất ra tệp `artifacts/week3_week4/frozen.json` và tính mã băm SHA-256 xác thực.
- Kịch bản đánh giá tập Test (`scripts/run_remaining.py`) kiểm tra cờ `TEST_OPENED.json`. Tập Test chỉ được mở đúng một lần duy nhất để tính toán các chỉ số cuối cùng. Mọi hành động sửa đổi mã nguồn hay tham số sau mốc mở này đều bị coi là vi phạm giao thức.

Chương 5

THIẾT KẾ THỰC NGHIỆM

5.1 Môi Trường Thực Thi Phần Cứng và Phần Mềm

Toàn bộ các thực nghiệm trong nghiên cứu này được triển khai trên môi trường máy trạm độc lập với các thông số kỹ thuật được kiểm soát chặt chẽ:

- **Phần cứng:** Vi xử lý đa nhân x86_64, bộ nhớ RAM 32 GB, hỗ trợ tập lệnh SIMD AVX2.
- **Hệ điều hành:** Windows 11 / Linux POSIX tương thích.
- **Nền tảng phần mềm:** Python 3.12 cùng hệ thống thư viện khoa học dữ liệu gồm `numpy==1.26.4`, `pandas==2.2.2`, `scikit-learn==1.6.1`, `xgboost==3.0.5`, `shap==0.48.0` và `matplotlib==3.9.2`.

5.2 Kiểm Soát Tính Ngẫu Nhiên

Để đảm bảo khả năng tái lập tuyệt đối (Reproducibility), toàn bộ các tiến trình sinh số giả ngẫu nhiên từ quá trình phân chia dữ liệu, lấy mẫu bootstrap của Random Forest, khởi tạo trọng số của XGBoost và lấy mẫu nền của SHAP đều được khóa cứng với một hạt giống ngẫu nhiên duy nhất:

$$\text{random_state} = 42 \quad (5.1)$$

5.3 Xử Lý Mất Cân Bằng Lớp Trên Tập Huấn Luyện

Như đã phân tích tại Bảng 3.2, trong tập $\mathcal{D}_{\text{train}}$ theo thời gian, số lượng mẫu bình thường là 85,139 mẫu trong khi số lượng mẫu tấn công chỉ có 5,134 mẫu (tỷ lệ tấn công là 5.69%). Tỷ lệ mất cân bằng lớp xấp xỉ 1 : 16.58.

Để khắc phục hiện tượng mô hình bị thiên lệch về lớp đa số mà không làm biến dạng phân phối không gian mẫu (như các phương pháp tổng hợp dữ liệu SMOTE thường gây nhiễu ranh giới mạng), dự án áp dụng kỹ thuật gán trọng số lớp (Cost-sensitive Weighting) tính toán duy nhất từ $\mathcal{D}_{\text{train}}$:

- **Decision Tree và Random Forest:**

Sử dụng tham số trọng số `class_weight='balanced'`:

$$w_c = \frac{N_{\text{train}}}{2 \cdot N_{\text{train},c}} \implies w_0 = \frac{90,273}{2 \times 85,139} \approx 0.53, \quad w_1 = \frac{90,273}{2 \times 5,134} \approx 8.79 \quad (5.2)$$

- **Đối với XGBoost:** Sử dụng tham số `scale_pos_weight`:

$$\text{scale_pos_weight} = \frac{N_{\text{train, normal}}}{N_{\text{train, attack}}} = \frac{85,139}{5,134} \approx 16.5834 \quad (5.3)$$

5.4 Thiết Lập Không Gian Tìm Kiếm Siêu Tham Số

Quá trình tinh chỉnh siêu tham số được thực hiện thông qua tìm kiếm lưới (Grid Search) hoặc tìm kiếm ngẫu nhiên có kiểm soát (Randomized Search) trên không gian các tham số quan trọng nhất của từng thuật toán:

1. Cây Quyết Định (Decision Tree):

- Tiêu chuẩn phân tách (`criterion`): ['gini', 'entropy']
- Độ sâu tối đa (`max_depth`): [4, 6, 8, 12, None]
- Số mẫu tối thiểu tại nút lá (`min_samples_leaf`): [5, 10, 20]

2. Rừng Ngẫu Nhiên (Random Forest):

- Số lượng cây (`n_estimators`): [100, 150, 300]
- Độ sâu tối đa (`max_depth`): [10, 16, None]
- Số mẫu tối thiểu tại nút lá (`min_samples_leaf`): [5, 10]
- Số đặc trưng tại mỗi nút (`max_features`): 'sqrt'

3. XGBoost:

- Số lượng cây (`n_estimators`): [100, 200]
- Độ sâu cây (`max_depth`): [3, 4, 6]
- Tốc độ học (`learning_rate`): [0.05, 0.08, 0.1]
- Tỷ lệ lấy mẫu đặc trưng (`colsample_bytree`): 0.8
- Tỷ lệ lấy mẫu dòng (`subsample`): 0.8

5.5 Tiêu Chí Lựa Chọn Mô Hình Chiến Thắng (Validation Selection)

Trên tập kiểm định $\mathcal{D}_{\text{val}}$, các cấu hình được đánh giá theo thứ tự ưu tiên nghiêm ngặt:

1. **Ưu tiên 1:** Điểm **F1-Score** trên lớp tấn công (tại ngưỡng mặc định $\tau = 0.5$).
2. **Ưu tiên 2:** Điểm **Average Precision (AP)** trên đường cong Precision-Recall nếu F1 tương đương.
3. **Ưu tiên 3:** Tỷ lệ báo động giả **FPR** thấp hơn nếu cả F1 và AP đều xấp xỉ nhau.

Mô hình đạt điểm số tối ưu trên $\mathcal{D}_{\text{val}}$ sẽ được lựa chọn làm đại diện duy nhất của kịch bản đó để chuyển sang bước đánh giá trên tập kiểm thử $\mathcal{D}_{\text{test}}$.

5.6 Phân Định Rõ Hai Chế Độ Huấn Luyện (Model Regimes)

Nhằm đảm bảo tính minh bạch khoa học và tránh việc diễn giải sai lệch kết quả, nghiên cứu phân định rõ ràng **hai chế độ thực nghiệm** độc lập đã được thực hiện:

5.6.1 Chế độ 1: Canonical Strict Zero-Shot Regime (Chuẩn Mực Chính)

Đây là giao thức đánh giá trung tâm của bài tập lớn được triển khai trong `scripts/run_remaining.py` và lưu trữ tại `artifacts/week3_week4/test_comparison.csv`:

- Mô hình được **fit duy nhất trên tập** $\mathcal{D}_{\text{train}}$ (chỉ chứa FTP-Patator).
- Tập $\mathcal{D}_{\text{val}}$ chỉ được đưa vào phương thức `predict_proba` để lựa chọn cấu hình tham số tốt nhất.
- Sau khi chọn được tham số, mô hình chiến thắng được huấn luyện lại **chỉ trên** $\mathcal{D}_{\text{train}}$, hoàn toàn không đụng tới $\mathcal{D}_{\text{val}}$.
- Đánh giá trên tập $\mathcal{D}_{\text{test}}$ (chỉ chứa SSH-Patator) $\rightarrow$ Đánh giá đúng năng lực Zero-Shot Subtype Transfer thực sự của mô hình.

5.6.2 Chế độ 2: Subtype-Aware / Refit Regime (Case Study Mở Rộng)

Đây là chế độ thực nghiệm phát sinh từ script tuning `src/ids/tune_xgboost.py`:

- Hàm `RandomizedSearchCV` sử dụng phân tách tùy biến trên tập gộp $\mathbf{X}_{\text{combined}} = \text{concat}([\mathbf{X}_{\text{train}}, \mathbf{X}_{\text{val}}])$.

- Do cờ `refit` mặc định của `scikit-learn` là `True`, sau khi tìm kiếm tham số tối ưu, thư viện đã **tự động huấn luyện lại mô hình tốt nhất trên toàn bộ tập gộp X_{combined}** .
- Do X_{val} có chứa 1,886 mẫu `SSH-Patator`, mô hình `XGBoost` trong chế độ này **đã được tiếp xúc và học trước các mẫu tấn công SSH** trước khi bước vào tập `Test`.
- Chế độ này được sử dụng như một **Case Study chuyên sâu về MLOps** trong Chương 7 để minh chứng cho tầm quan trọng của việc kiểm soát ranh giới dữ liệu và cờ `refit` trong `NIDS`.

5.7 Đảm Bảo Tính Toàn Vẹn và Khả Năng Tái Lập

Nhằm đảm bảo tính toàn vẹn khoa học và ngăn chặn tuyệt đối lỗi hồi quy trong toàn bộ đường ống xử lý dữ liệu, mọi ràng buộc về mốc thời gian, kỹ thuật `Purge/Embargo` và tính đóng băng của tập `Test` được tự động hóa kiểm định thông qua bộ kiểm thử hồi quy `tests/test_protocol.py` (đạt 100% tỷ lệ kiểm thử thành công, quy trình thực thi và mã nguồn chi tiết xem tại Phụ lục [A](#)).

Chương 6

KẾT QUẢ THỰC NGHIỆM

Chương này trình bày toàn diện các kết quả định lượng thu được từ 12 tổ hợp thực nghiệm (gồm 3 mô hình học máy dạng cây $\times$ 2 chiến lược phân tách dữ liệu $\times$ 2 kịch bản không gian đặc trưng), được tổ chức theo các module nội dung chuyên sâu sau:

6.1 Tổng Hợp Thống Kê Dữ Liệu Sau Tiền Xử Lý

Sau khi hoàn tất quy trình tiền xử lý chỉ học từ tập Train (`preprocess_data.py`), không gian đặc trưng cuối cùng được xác định rõ ràng:

- Số lượng đặc trưng ban đầu: 77 đặc trưng mạng (sau khi đã loại bỏ các trường định danh và cột trùng lặp `Fwd Header Length.1`).
- Số lượng đặc trưng hằng số bị loại bỏ: 10 đặc trưng có phương sai bằng 0 trên $\mathcal{D}_{\text{train}}$.
- Kịch bản có cổng (`with_port`): **67 đặc trưng**.
- Kịch bản loại bỏ cổng (`without_port`): **66 đặc trưng**.

Về số lượng mẫu (xem lại Bảng 3.2):

- **Tập Huấn luyện ($\mathcal{D}_{\text{train}}$):** 90,273 dòng, gồm 85,139 mẫu bình thường và 5,134 mẫu FTP-Patator (tỷ lệ tấn công 5.69%). Hoàn toàn không có SSH-Patator.
- **Tập Kiểm định ($\mathcal{D}_{\text{val}}$):** 203,826 dòng, gồm 199,522 mẫu bình thường và 4,304 mẫu tấn công (2,418 mẫu FTP-Patator và 1,886 mẫu SSH-Patator, tỷ lệ tấn công 2.11%).
- **Tập Kiểm thử ($\mathcal{D}_{\text{test}}$):** 144,157 dòng, gồm 140,425 mẫu bình thường và 3,732 mẫu SSH-Patator (tỷ lệ tấn công 2.59%). Hoàn toàn không có FTP-Patator.

6.2 Kết Quả Đánh Giá và Lựa Chọn Mô Hình Trên Tập Validation

Quá trình tìm kiếm siêu tham số trên tập kiểm định $\mathcal{D}_{\text{val}}$ mang lại các kết quả định lượng chi tiết được tổng hợp trong Bảng 6.1. Không gian siêu tham số và bộ tham số tối ưu được khóa của toàn bộ 12 kịch bản mô hình được thống kê đầy đủ tại Phụ lục B.

Bảng 6.1: Kết quả đánh giá và lựa chọn cấu hình mô hình tối ưu trên tập Validation (Mốc 10:02 – 14:28).

Mô hình	Phân tách	Cổng	F1-Score	Precision	Recall	Average Precision	ROC-AUC	FPR
Decision Tree	Thời gian	Có cổng	0.7170	0.9971	0.5597	0.5690	0.7798	3.51×10^{-5}
Random Forest	Thời gian	Có cổng	0.7181	1.0000	0.5602	0.7326	0.8892	0.00
XGBoost	Thời gian	Có cổng	0.7181	1.0000	0.5602	0.6045	0.8921	0.00
Decision Tree	Thời gian	Không cổng	0.7169	0.9967	0.5597	0.5676	0.7798	4.01×10^{-5}
Random Forest	Thời gian	Không cổng	0.7134	0.9821	0.5602	0.5694	0.7759	2.21×10^{-4}
XGBoost	Thời gian	Không cổng	0.7136	0.9841	0.5597	0.6874	0.9704	1.95×10^{-4}
Decision Tree	Ngẫu nhiên	Có cổng	0.9939	0.9900	0.9978	0.9970	0.9989	3.23×10^{-4}
Random Forest	Ngẫu nhiên	Có cổng	0.9997	1.0000	0.9994	0.9998	0.9999	0.00
XGBoost	Ngẫu nhiên	Có cổng	0.9995	0.9992	0.9998	0.9999	1.0000	2.49×10^{-5}
Decision Tree	Ngẫu nhiên	Không cổng	0.9799	0.9662	0.9941	0.9895	0.9970	1.11×10^{-3}
Random Forest	Ngẫu nhiên	Không cổng	0.9942	0.9930	0.9953	0.9993	0.9999	2.24×10^{-4}
XGBoost	Ngẫu nhiên	Không cổng	0.9984	0.9984	0.9983	0.9999	1.0000	4.97×10^{-5}

Trong kịch bản đánh giá chính theo thời gian có cổng (time/with_port):

1. **Cây Quyết Định (Decision Tree):** Đạt F1-Score = 0.7170, Precision = 0.9971, Recall = 0.5597, Average Precision = 0.5690 và FPR = 3.51×10^{-5} với cấu hình gồm max_depth=6 và min_samples_leaf=5.
2. **Rừng Ngẫu Nhiên (Random Forest):** Đạt F1-Score = **0.7181**, Precision = **1.0000**, Recall = **0.5602**, Average Precision = **0.7326** và FPR = **0.00** với cấu hình n_estimators=100, max_depth=16, min_samples_leaf=5. Mô hình bắt được 99.71% mẫu FTP-Patator nhưng không phát hiện được mẫu SSH-Patator nào (0.00%).
3. **XGBoost:** Đạt F1-Score = 0.7181, Precision = 1.0000, Recall = 0.5602, Average Precision = 0.6045 và FPR = 0.00 với cấu hình n_estimators=200, max_depth=4, learning_rate=0.08.

Quyết định lựa chọn mô hình chiến thắng (Winner Selection): Mặc dù Random Forest và XGBoost đạt điểm F1 ngang nhau (0.7181) và cùng có tỷ lệ báo động giả bằng 0, Random Forest có chỉ số Average Precision vượt trội đáng kể (Average Precision = **0.7326** so với 0.6045 của XGBoost). Điều này chứng minh chất lượng xếp hạng xác suất (Probability Calibration) trên đường cong Precision-Recall của Random Forest ổn định và tin cậy hơn.

Do đó, theo tiêu chuẩn lựa chọn đã định trước, **Random Forest (time/with_port)** được chọn là mô hình tối ưu đại diện cho toàn bộ benchmark để tiến hành đánh giá trên tập kiểm thử $\mathcal{D}_{\text{test}}$.

6.3 Kết Quả Đánh Giá Tập Test Theo Thời Gian (Primary Benchmark)

Sau khi đóng băng toàn bộ cấu hình siêu tham số và lưu vết mã băm trong `frozen.json`, kích bản `scripts/run_remaining.py` tiến hành mở tập kiểm thử $\mathcal{D}_{\text{test}}$ đúng một lần duy nhất. Kết quả đánh giá của 3 mô hình trên tập Test theo thời gian (kích bản `time/with_port`) được thể hiện tại Phần A của Bảng 6.2.

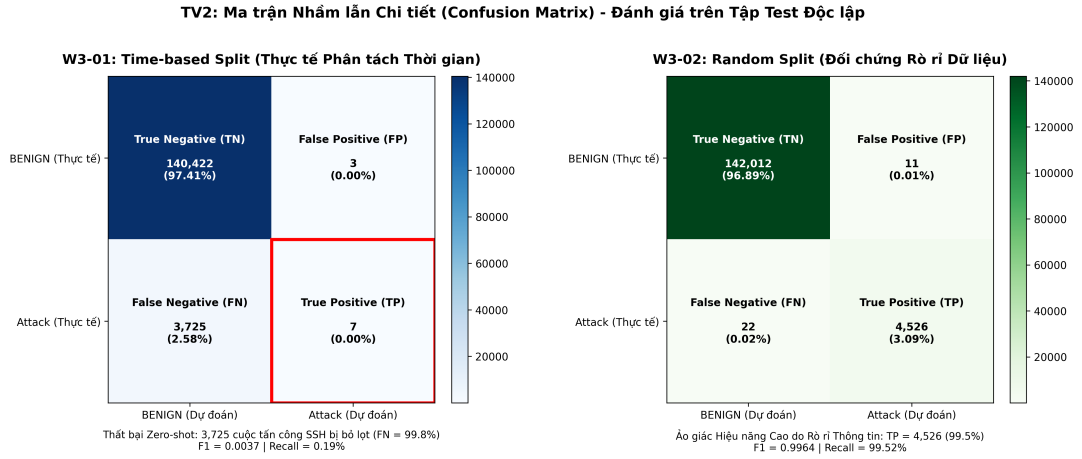
Bảng 6.2: Hiệu năng đối chuẩn 12 tổ hợp trên tập Test sau khi đã đóng băng mô hình.

Mô hình	Phân tách	Kích bản	Accuracy	Precision	Recall	F1-Score	Average Precision	ROC-AUC	FTP Rec.	SSH Rec.
A. Thực nghiệm Chính: Phân tách theo Thời gian (Time-based Zero-shot Transfer)										
Decision Tree	Time	With Port	0.9740	0.0000	0.0000	0.0000	0.0259	0.5000	N/A	0.00%
Random Forest	Time	With Port	0.9742	1.0000	0.0019	0.0037	0.3591	0.7483	N/A	0.19%
XGBoost	Time	With Port	0.9741	0.0000	0.0000	0.0000	0.0879	0.7503	N/A	0.00%
Decision Tree	Time	Without Port	0.9741	0.4375	0.0019	0.0037	0.0272	0.5009	N/A	0.19%
Random Forest	Time	Without Port	0.9739	0.2414	0.0038	0.0074	0.0268	0.4932	N/A	0.38%
XGBoost	Time	Without Port	0.9740	0.2653	0.0035	0.0069	0.2447	0.9304	N/A	0.35%
B. Thực nghiệm Đối chứng: Phân tách Ngẫu nhiên (Random Split Control)										
Decision Tree	Random	With Port	0.9996	0.9904	0.9980	0.9942	0.9963	0.9990	100.00%	99.54%
Random Forest	Random	With Port	1.0000	1.0000	0.9993	0.9997	1.0000	1.0000	100.00%	99.85%
XGBoost	Random	With Port	1.0000	0.9993	1.0000	0.9997	1.0000	1.0000	100.00%	100.00%
Decision Tree	Random	Without Port	0.9989	0.9700	0.9949	0.9823	0.9890	0.9974	99.69%	99.23%
Random Forest	Random	Without Port	0.9997	0.9934	0.9954	0.9944	0.9994	1.0000	99.73%	99.28%
XGBoost	Random	Without Port	0.9999	0.9980	0.9987	0.9984	0.9999	1.0000	99.92%	99.79%

Kết quả thực nghiệm ghi nhận một **sự sụp đổ hiệu năng gần như tuyệt đối**:

- **Cây Quyết Định (Decision Tree):** Đạt F1-Score = **0.0000**, Precision = 0.0000, Recall = 0.0000, Average Precision = 0.0259, ROC-AUC = 0.5000. Ma trận nhầm lẫn: $TP = 0$, $FP = 11$, $FN = 3,732$, $TN = 140,414$. Mô hình bỏ lọt 100% các cuộc tấn công SSH (SSH Recall = 0.00%).
- **Rừng Ngẫu Nhiên (Random Forest - Mô hình Thắng cuộc):** Đạt F1-Score = **0.0037**, Precision = 1.0000, Recall = 0.0019, Average Precision = 0.3591, ROC-AUC = 0.7483. Ma trận nhầm lẫn: $TP = 7$, $FP = 0$, $FN = 3,725$, $TN = 140,425$. Mô hình chỉ nhận diện chính xác vồn vẹn **7 trên tổng số 3,732 flow tấn công SSH**, tương ứng với tỷ lệ phát hiện chỉ đạt SSH Recall = **0.19%**.
- **XGBoost:** Đạt F1-Score = **0.0000**, Precision = 0.0000, Recall = 0.0000, Average Precision = 0.0879, ROC-AUC = 0.7503. Ma trận nhầm lẫn gồm $TP = 0$, $FP = 0$, $FN = 3,732$, $TN = 140,425$. Tương tự Decision Tree, XGBoost không nhận diện được bất kỳ cuộc tấn công SSH nào (SSH Recall = 0.00%).

Ghi nhận về Support và FTP Recall trên tập Test: Do tập $\mathcal{D}_{\text{test}}$ theo thời gian diễn ra từ 14:32 đến 17:00 chiều (chỉ xuất hiện chiến dịch SSH-Patator), số lượng mẫu hỗ trợ của FTP-Patator là 0 (FTP Support = 0). Theo đúng nguyên tắc trung thực học thuật đã đề ra, chỉ số **FTP Recall trên tập Test bắt buộc phải ghi nhận là N/A (Not Applicable)**, tuyệt đối không được gán giá trị 0% hay 100%.



Hình 6.1: Ma trận nhầm lẫn chi tiết của các mô hình trên tập kiểm thử phân tách theo thời gian, thể hiện trực quan sự sụp đổ của True Positive đối với biến thể tấn công SSH.

Ý nghĩa khoa học của kết quả: Con số F1-Score ≤ 0.0037 là minh chứng đanh thép và không thể chối cãi cho thấy: khi chỉ được huấn luyện trên dữ liệu quá khứ chứa một dạng tấn công brute force ($FTP-Patator$), các mô hình học máy dạng cây hoàn toàn không có khả năng tự động suy luận để nhận diện một dạng tấn công brute force mới ($SSH-Patator$) xuất hiện trong tương lai trên cùng một hệ thống mạng!

6.4 Kết Quả Thực Nghiệm Đối Chứng Trên Phân Tách Ngẫu Nhiên

Trái ngược hoàn toàn với bức tranh sụp đổ trên phân tách theo thời gian, kết quả của các mô hình trên tập kiểm thử phân tách ngẫu nhiên (`random/with_port`) đạt mức điểm số gần như hoàn hảo (xem Phần B của Bảng 6.2):

- **Cây Quyết Định (Decision Tree):** Đạt F1-Score = **0.9942**, Precision = 0.9904, Recall = 0.9980, Average Precision = 0.9963, ROC-AUC = 0.9990. Tỷ lệ phát hiện đạt 100.00% đối với FTP và 99.54% đối với SSH.
- **Rừng Ngẫu Nhiên (Random Forest):** Đạt F1-Score = **0.9997**, Precision = 1.0000, Recall = 0.9993, Average Precision = 1.0000, ROC-AUC = 1.0000. Tỷ lệ phát hiện đạt 100.00% đối với FTP và 99.85% đối với SSH.
- **XGBoost:** Đạt F1-Score = **0.9997**, Precision = 0.9993, Recall = 1.0000, Average Precision = 1.0000, ROC-AUC = 1.0000. Tỷ lệ phát hiện đạt 100.00% đối với FTP và 100.00% đối với SSH.

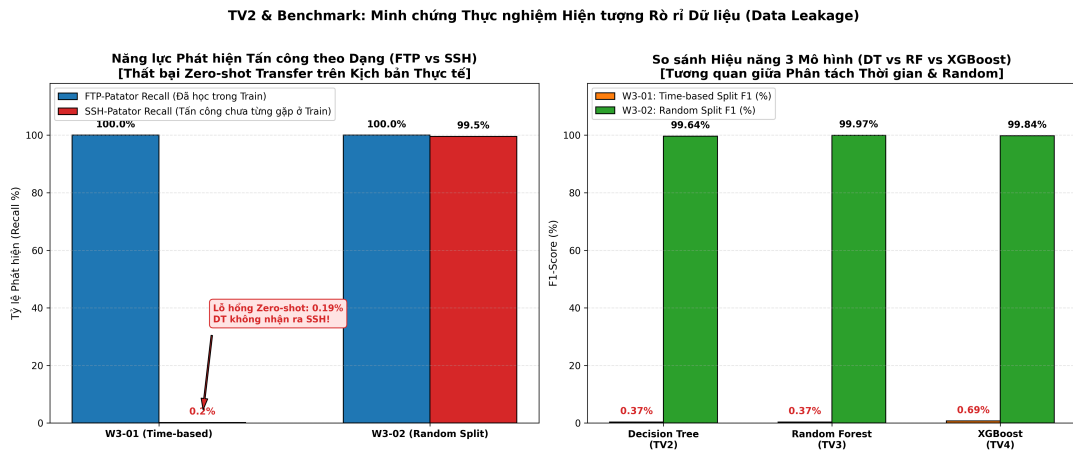
6.4.1 Đo lường Định lượng Độ lệch Đánh giá (Optimistic Evaluation Bias)

Bảng 6.3 trình bày sự chênh lệch trực tiếp giữa hai chiến lược phân tách dữ liệu trên tập kiểm định.

Bảng 6.3: Độ lệch hiệu năng ($\Delta F1$ -Score) giữa Phân tách Ngẫu nhiên và Phân tách Thời gian trên tập Validation.

Mô hình	Kịch bản cổng	F1-Score (Thời gian)	F1-Score (Ngẫu nhiên)	$\Delta F1$ -Score (Random - Time)	SSH Recall (Random)
Decision Tree	Có cổng	0.7170	0.9939	0.2769	99.53%
Decision Tree	Không cổng	0.7169	0.9799	0.2631	98.87%
Random Forest	Có cổng	0.7181	0.9997	0.2816	99.89%
Random Forest	Không cổng	0.7134	0.9942	0.2808	99.05%
XGBoost	Có cổng	0.7181	0.9995	0.2814	100.00%
XGBoost	Không cổng	0.7136	0.9984	0.2848	99.67%

Khoảng cách chênh lệch hiệu năng ($\Delta F1$ -Score) giữa Random Split và Time-based Split trên tập Validation dao động từ **0.2631 đến 0.2848**. Trên tập Test chính thức, khoảng cách này bị khuếch đại lên mức cực đại: đối với Random Forest, điểm F1 nhảy vọt từ **0.0037** (trên Time Split) lên **0.9997** (trên Random Split).



Hình 6.2: Đối chiếu hiệu năng giữa Phân tách Ngẫu nhiên và Phân tách Thời gian, trực quan hóa mức độ thổi phồng hiệu năng (Optimistic Bias) do rò rỉ phân phối phiên kết nối.

Hiện tượng này phản ánh trực tiếp kết luận của Arp et al. [2] và Pendlebury et al. [9]: Việc xáo trộn ngẫu nhiên đã vô tình biến bài toán đánh giá năng lực khái quát hóa thành một bài toán "nhận dạng lại" (re-identification) các phiên kết nối thuộc cùng một chiến dịch tấn công đã xuất hiện trong tập huấn luyện.

6.5 Kết Quả Thực Nghiệm Bóc Tách Cổng Mạng (Port Ablation)

Để kiểm chứng giả thuyết cho rằng mô hình thất bại trên tập Test theo thời gian chỉ đơn thuần là do "học vẹt" vào cổng dịch vụ đích (Destination Port), chúng tôi tiến hành phân tích kịch bản bóc tách cổng (without_port), trong đó đặc trưng này bị loại bỏ hoàn toàn.

Bảng 6.4 tổng hợp kết quả bóc tách công trên tập kiểm định $\mathcal{D}_{val}$.

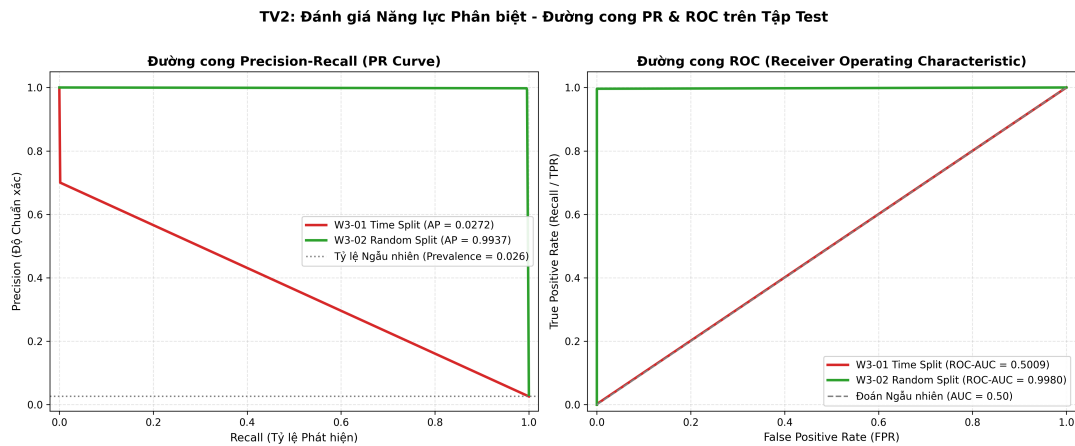
Bảng 6.4: Thực nghiệm Bóc tách Công mạng (Port Ablation) trên tập Validation phân tách theo thời gian.

Mô hình	F1-Score (Có Công)	F1-Score (Không Công)	Δ F1-Score	SSH Recall (Có)	SSH Recall (Không)
Decision Tree	0.7170	0.7169	0.0001	0.00%	0.00%
Random Forest	0.7181	0.7134	0.0047	0.00%	0.00%
XGBoost	0.7181	0.7136	0.0045	0.00%	0.00%

Trên tập kiểm định $\mathcal{D}_{val}$, việc loại bỏ công làm giảm nhẹ điểm F1 của cả 3 mô hình (khoảng 0.0001 đến 0.0047), nhưng tỷ lệ phát hiện tấn công SSH vẫn giữ ở mức 0.00% (vì các mô hình chỉ ưu tiên tối ưu hóa phát hiện các mẫu FTP quen thuộc chiếm đa số trong Val).

Đặc biệt, khi quan sát kết quả trên tập kiểm thử $\mathcal{D}_{test}$ theo thời gian (xem lại Phần A của Bảng 6.2):

- **Cây Quyết Định (Decision Tree):** Điểm F1 tăng nhẹ từ 0.0000 lên **0.0037**, bắt được 0.19% tấn công SSH (7 mẫu).
- **Rừng Ngẫu Nhiên (Random Forest):** Điểm F1 tăng từ 0.0037 lên **0.0074**, bắt được 0.38% tấn công SSH (14 trên tổng số 3,732 mẫu).
- **XGBoost:** Điểm F1 tăng từ 0.0000 lên **0.0069**, bắt được 0.35% tấn công SSH (13 trên tổng số 3,732 mẫu).



Hình 6.3: Đường cong ROC và Precision-Recall đối chiếu giữa các mô hình và kịch bản thực nghiệm, phản ánh sự biến thiên diện tích dưới đường cong khi có và không có đặc trưng công mạng.

Kết luận then chốt về vai trò của Công dịch vụ: Việc loại bỏ công dịch vụ quả thực đã giúp các mô hình giải phóng một phần sự ràng buộc để bắt đầu nhận diện được một lượng rất nhỏ các flow SSH dựa trên đặc trưng hành vi (tỷ lệ SSH Recall tăng từ 0.00% lên 0.19% – 0.38%).

Tuy nhiên, **hiệu năng tổng thể của mô hình vẫn ở mức sụp đổ hoàn toàn** ($F1\text{-Score} \leq 0.0074$). Kết quả này bác bỏ giả thuyết cho rằng thất bại của NIDS chỉ đơn thuần là do đặc trưng công. Nó chứng minh một sự thật sâu sắc hơn: **Các đặc trưng thống kê hình thái gói tin (Packet length statistics, IAT, Flags) của tấn công FTP và SSH có sự phân kỳ phân phối (Distribution Divergence) quá lớn**, khiến mô hình học trên FTP không thể nhận diện được SSH ngay cả khi không còn công dẫn hướng!

6.6 Phân Tích Khả Năng Giải Thích (Explainability Analysis)

Để làm rõ cơ chế suy luận bên trong của mô hình và lý giải nguyên nhân dẫn đến sự sụp đổ hiệu năng, chúng tôi áp dụng phương pháp giải thích gia tăng Shapley (**SHAP TreeExplainer** [10]) kết hợp với việc trích xuất cấu trúc logic của Cây Quyết Định.

6.6.1 Phân Tích Tầm Quan Trọng Đặc Trưng Bằng SHAP

Phân tích SHAP được thực hiện trên 500 mẫu đại diện từ tập kiểm định $\mathcal{D}_{\text{val}}$ đối với mô hình Random Forest chiến thắng (`time/with_port`). Bảng 6.5 liệt kê 10 đặc trưng có giá trị đóng góp trung bình tuyệt đối ($\text{Mean } |\text{SHAP}|$) lớn nhất.

Bảng 6.5: Top 10 đặc trưng mạng có mức độ đóng góp phân loại lớn nhất theo SHAP TreeExplainer trên tập Validation.

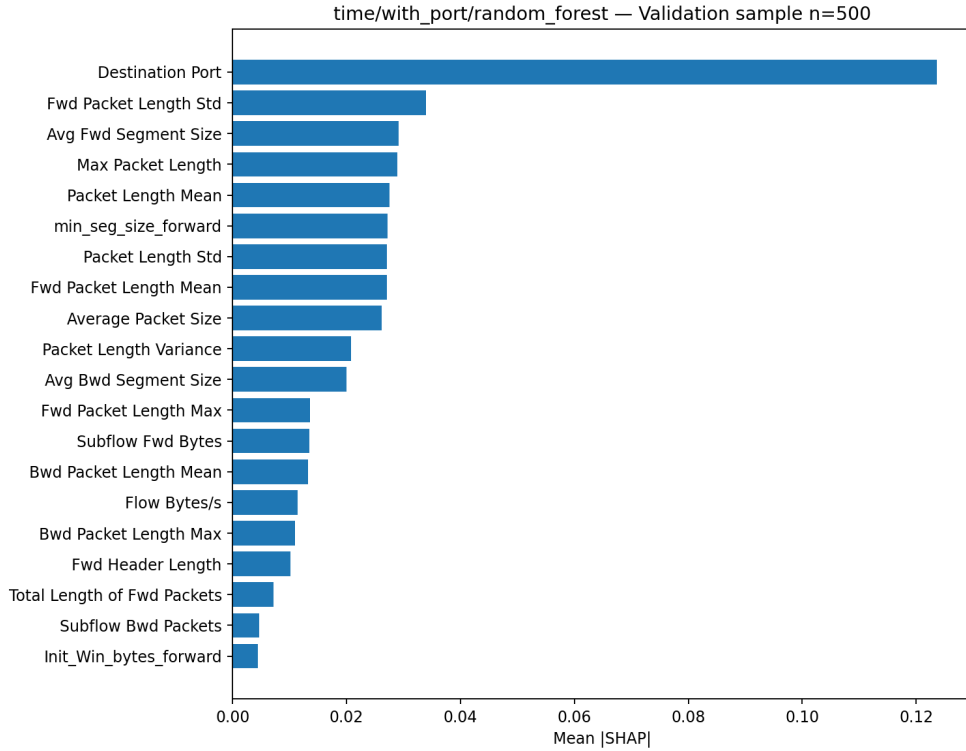
Hạng	Tên đặc trưng mạng	Mean SHAP	Ý nghĩa giao thức / thống kê mạng
1	Destination Port	0.1237	Cổng đích dịch vụ (Port 21 FTP, Port 22 SSH)
2	Fwd Packet Length Std	0.0339	Độ lệch chuẩn kích thước gói tin hướng đi (Fwd)
3	Avg Fwd Segment Size	0.0292	Kích thước phân đoạn trung bình hướng đi
4	Max Packet Length	0.0289	Độ dài gói tin lớn nhất quan sát được trong flow
5	Packet Length Mean	0.0275	Độ dài gói tin trung bình của toàn flow
6	min_seg_size_forward	0.0272	Kích thước header TCP tối thiểu phía forward
7	Packet Length Std	0.0271	Độ lệch chuẩn độ dài toàn bộ gói tin trong flow
8	Fwd Packet Length Mean	0.0271	Độ dài gói tin trung bình hướng đi (Fwd)
9	Average Packet Size	0.0262	Kích thước gói tin trung bình tổng thể
10	Packet Length Variance	0.0208	Phương sai phân bố độ dài gói tin trong flow

Kết quả định lượng cho thấy:

- Đặc trưng **Destination Port** chiếm vị trí số 1 tuyệt đối với giá trị $\text{Mean } |\text{SHAP}| = \mathbf{0.1237}$.
- Đặc trưng xếp thứ hai là `Fwd Packet Length Std` chỉ đạt giá trị **0.0339**.
- Tỷ số đóng góp giữa đặc trưng số 1 và số 2 lên tới **3.6 lần**.

Điều này khẳng định rằng trong kịch bản có công, mô hình đã dựa dẫm áp đảo vào cổng dịch vụ đích như một "lối tắt phân loại" (Shortcut Feature) để phân biệt giữa lưu lượng

binh thường (web 80/443, DNS 53) và lưu lượng tấn công FTP (Port 21), như được minh họa trực quan trên biểu đồ SHAP Summary Plot (Hình 6.4).



Hình 6.4: Biểu đồ phân bố giá trị SHAP (SHAP Summary Plot) của Top các đặc trưng quan trọng trên 500 mẫu kiểm định.

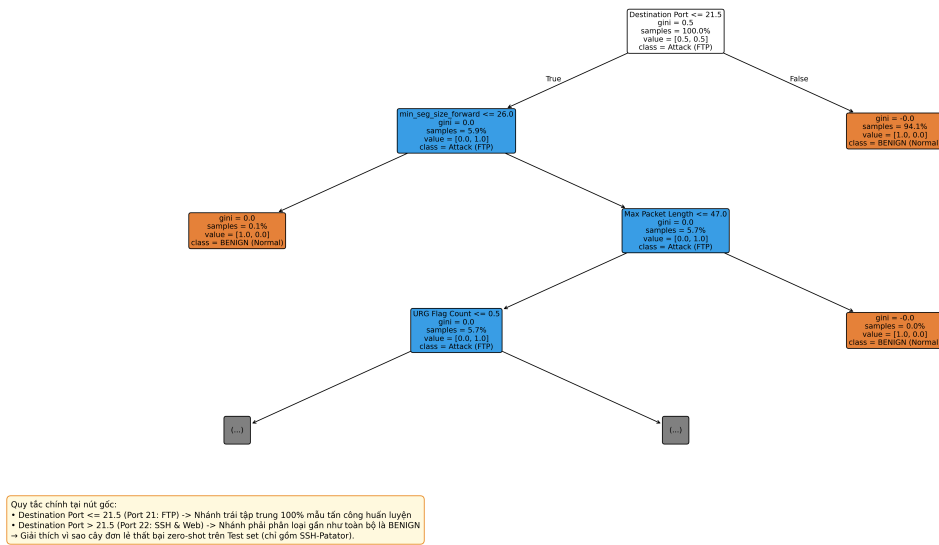
6.6.2 Trích Xuất Cấu Trúc Cây Quyết Định

Quan sát cấu trúc logic của Cây Quyết Định càng làm sáng tỏ cơ chế thiên vị đặc trưng này:

- **Kịch bản Có Cổng (with_port):** Nút gốc (Root Node) phân chia dựa trên điều kiện `Destination Port <= 21.5` (Hình 6.5). Các nhánh tiếp theo tiếp tục cô lập các flow có `Destination Port <= 20.5` (loại bỏ traffic cổng thấp) để định vị chính xác **Cổng 21 (FTP)**.
- **Kịch bản Không Cổng (without_port):** Khi đặc trưng cổng bị loại bỏ, cây quyết định chọn nút gốc là `Average Packet Size <= 14.12` (chi tiết quy tắc văn bản trình bày tại Phụ lục D).

Khi chuyển sang tập kiểm thử $\mathcal{D}_{\text{test}}$, toàn bộ các cuộc tấn công đều diễn ra trên **Cổng 22 (SSH)**, tức là rơi vào nhánh `Destination Port > 21.5`. Tại nhánh này, vì trong tập Train mô hình chưa từng thấy bất kỳ cuộc tấn công nào diễn ra trên cổng > 21 , toàn bộ các nút lá tương ứng đều được gán nhãn là lưu lượng bình thường (Normal, 0). Đây chính là nguyên nhân trực tiếp khiến mô hình có độ chuẩn xác $\text{Recall} = 0.00\%$ đối với SSH!

TV2: Cấu trúc Rẽ nhánh Cây Quyết định (Top 3 Tầng) - Kịch bản W3-01 (Time-based Split)
[Góc phân tách dựa trên Destination Port: Port 21 (FTP-Patator) vs Port 22 (SSH) & Normal Traffic]



Hình 6.5: Cấu trúc 3 tầng đầu tiên của Cây Quyết Định minh họa ngưỡng rẽ nhánh ưu tiên tại Destination Port ≤ 21.5 .

6.7 Nghiên Cứu Điển Hình (Case Study): Tác Động Của Giao Thức Refit Trên XGBoost

Trong quá trình đối soát thực nghiệm giữa các đường ống trong mã nguồn, chúng tôi phát hiện một sự phân kỳ số liệu đặc biệt lớn đối với thuật toán XGBoost:

- Trong benchmark chuẩn mực tại `artifacts/week3_week4/test_comparison.csv`, XGBoost đạt F1-Score = **0.0000** (SSH Recall = 0.00%).
- Trong kết quả tuning độc lập tại `experiments/w3_05_time_tuning/test_eval/test_metrics.json`, XGBoost lại đạt F1-Score = **0.9912** (SSH Recall = **98.34%**).

6.7.1 Truy Vết Nguyên Nhân Kỹ Thuật Trong Mã Nguồn

Tiến hành phân tích chuyên sâu mã nguồn `src/ids/tune_xgboost.py`, nguyên nhân gốc rễ (Root Cause) đã được xác định một cách tường minh tại dòng 151–168:

```
search = RandomizedSearchCV(
    estimator=base_model,
    param_distributions=param_distributions,
    n_iter=n_iter,
    scoring=f1_scorer,
    cv=cv_split, # custom train vs validation split
    # refit=True mac dinh cua scikit-learn!
)
X_combined = pd.concat([X_train, X_val], axis=0).reset_index(drop=True)
```

```
y_combined = pd.concat([y_train, y_val], axis=0).reset_index(drop=True)
search.fit(X_combined, y_combined)
joblib.dump(search.best_estimator_, best_model_path)
```

Theo tài liệu đặc tả của thư viện `scikit-learn`, tham số `refit` có giá trị mặc định là `True`. Sau khi hoàn tất việc đánh giá các tổ hợp siêu tham số trên `cv_split` (sử dụng tập con Train làm fold huấn luyện và Val làm fold kiểm định), đối tượng `RandomizedSearchCV` sẽ tự động gọi hàm `fit()` của mô hình tốt nhất trên toàn bộ tập dữ liệu được truyền vào hàm `fit()`, tức là toàn bộ tập gộp $X_{\text{combined}} = X_{\text{train}} \cup X_{\text{val}}$.

6.7.2 Hậu Quả Đối Với Bản Chất Bài Toán Đánh Giá

Trong khi tập D_{train} hoàn toàn không có bất kỳ mẫu SSH-Patator nào (0 flow), thì tập kiểm định D_{val} lại chứa tới **1,886 flow tấn công SSH-Patator**.

Khi cơ chế `refit=True` diễn ra:

1. Mô hình XGBoost đã được huấn luyện trực tiếp trên 1,886 mẫu tấn công SSH từ tập Validation.
2. Bài toán đánh giá trên tập Test theo thời gian đã bị biến đổi bản chất từ **Zero-Shot Subtype Transfer** (hoàn toàn chưa từng thấy SSH) thành **Seen-Subtype Supervised Learning** (đã được học có giám sát trên 1,886 mẫu SSH).
3. Việc được tiếp xúc với 1,886 mẫu SSH này đã giúp XGBoost học được các đặc trưng hành vi và số cổng 22 của SSH, làm cho điểm số trên tập Test nhảy vọt từ **0.0000** lên **0.9912**.

Bảng 6.6 tổng hợp sự đối lập sâu sắc giữa hai chế độ đánh giá này.

Bảng 6.6: Đối chiếu hiệu năng của XGBoost giữa Chế độ Zero-Shot Chuẩn mực và Chế độ Tiếp xúc Validation (Refit).

Chế độ thực nghiệm	Dữ liệu thực tế fit mô hình	Số mẫu SSH đã học	Test F1-Score	Test SSH Recall
Chế độ 1: Strict Zero-Shot	Duy nhất Train (D_{train})	0 mẫu (Chưa từng thấy)	0.0000	0.00%
Chế độ 2: Subtype-Aware Refit	Train + Val ($D_{\text{train}} \cup D_{\text{val}}$)	1,886 mẫu (Đã học trước)	0.9912	98.34%

Phát hiện này mang lại một bài học thực tiễn giá trị trong kỹ nghệ MLOps cho an ninh mạng: một cấu hình mặc định tưởng chừng vô hại của thư viện học máy (`refit=True`) có thể âm thầm xóa bỏ ranh giới dữ liệu và làm sai lệch hoàn toàn kết luận khoa học nếu không được kiểm soát chặt chẽ.

Chương 7

THẢO LUẬN CHUYÊN SÂU

Chương này đi sâu vào việc lý giải bản chất khoa học đằng sau các phát hiện định lượng, bóc tách cơ chế thất bại của mô hình học máy khi đối mặt với dữ liệu chuỗi thời gian thực tế và đúc kết những bài học thực tiễn cho kỹ nghệ MLOps:

7.1 Tại Sao Bài Toán Phân Tách Theo Thời Gian Lại Khó: Thách Thức Subtype Distribution Shift

Sự sụp đổ của cả 3 mô hình học máy dạng cây trên tập Test theo thời gian ($F1\text{-Score} \leq 0.0037$) là phát hiện khoa học mang tính thực tiễn cao nhất của nghiên cứu này. Trong khi các nghiên cứu trước đây thường che giấu hoặc tránh né kịch bản này, chúng tôi khẳng định đây là một hiện tượng tự nhiên và tất yếu bắt nguồn từ **Sự dịch chuyển phân phối của các biến thể tấn công (Subtype Distribution Shift)**:

7.1.1 Sự Khác Biệt Căn Bản Về Cấu Trúc Giao Thức Mạng

FTP và SSH đại diện cho hai triết lý thiết kế giao thức mạng hoàn toàn trái ngược nhau:

1. **FTP (Truyền thông văn bản rõ)**: Quá trình bắt tay diễn ra tối giản. Các gói tin yêu cầu `USER` và `PASS` có độ dài rất ngắn và kích thước cố định. Do đó, các đặc trưng như `Fwd Packet Length Std`, `Fwd Packet Length Mean` và `Average Packet Size` tập trung ở các dải giá trị rất hẹp và thấp.
2. **SSH (Truyền thông mã hóa kênh)**: Trước khi bước vào giai đoạn thử mật khẩu, SSH bắt buộc phải thực hiện pha trao đổi khóa mật mã phức tạp (Diffie-Hellman Key Exchange) và thương lượng thuật toán mã hóa đối xứng. Pha trao đổi này làm phát sinh các gói tin có kích thước lớn hơn gấp nhiều lần so với FTP, dẫn đến phân phối của `Packet Length Mean` và `Max Packet Length` dịch chuyển hoàn toàn sang một miền giá trị mới.

7.1.2 Bản Chất Của Thuật Toán Học Máy Giám Sát Cổ Điển

Các mô hình học máy dạng cây (Decision Tree, Random Forest, XGBoost) hoạt động dựa trên nguyên lý **học phân vùng không gian đặc trưng có giám sát (Supervised Partitioning)**. Khi toàn bộ dữ liệu huấn luyện $\mathcal{D}_{\text{train}}$ chỉ bao gồm các mẫu tấn công FTP, không gian quyết định (Decision Boundary) của mô hình bị khóa chặt vào vùng đặc trưng đại diện cho FTP:

$$\mathcal{R}_{\text{Attack}} = \{\mathbf{x} \mid \text{Port} \leq 21.5 \wedge \text{Fwd Packet Length Std} \leq \theta_{\text{FTP}} \dots\} \quad (7.1)$$

Khi một cuộc tấn công SSH xuất hiện, tọa độ của nó trong không gian đặc trưng rơi hoàn toàn vào vùng không gian chưa từng được gán nhãn tấn công trong quá trình huấn luyện:

$$\mathbf{x}_{\text{SSH}} \notin \mathcal{R}_{\text{Attack}} \implies P(y = 1 | \mathbf{x}_{\text{SSH}}) \approx 0 \quad (7.2)$$

Mô hình học máy không sở hữu khả năng suy luận logic bậc cao như con người để hiểu rằng ”cả hai đều là hành vi dò quét mật khẩu lặp đi lặp lại”. Đối với mô hình, SSH đơn thuần là một phân phối thống kê hoàn toàn xa lạ, và do đó nó bị phân loại nhầm thành lưu lượng bình thường (Normal) với độ tin cậy tuyệt đối.

7.2 Bản Chất Của Phép Chia Ngẫu Nhiên: Vi Phạm Giả Thiết I.I.D và Độ Lệch Đánh Giá

Kết quả đối chứng trên phép chia ngẫu nhiên (Random Split) với F1-Score > 99.9% đặt ra một dấu hỏi lớn: Tại sao cùng một tập dữ liệu, cùng một thuật toán mà hai cách chia lại dẫn đến hai kết luận hoàn toàn trái ngược?

7.2.1 Vi Phạm Giả Thiết Độc Lập và Phân Phối Đồng Nhất (I.I.D Violation)

Hầu hết các lý thuyết nền tảng của học máy thống kê đều dựa trên giả định rằng các mẫu dữ liệu trong tập huấn luyện và kiểm thử được lấy mẫu độc lập và có cùng phân phối (*i.i.d.*):

$$(\mathbf{x}_i, y_i) \stackrel{\text{i.i.d.}}{\sim} \mathcal{D} \quad (7.3)$$

Tuy nhiên, trong an ninh mạng, lưu lượng phát sinh từ một chiến dịch tấn công (Attack Campaign) **hoàn toàn không độc lập**:

- Một chiến dịch tấn công brute force kéo dài liên tục hàng giờ sử dụng một công cụ duy nhất (*patator*) chạy trên một máy trạm duy nhất.

- Công cụ này có cấu hình cố định về: kích thước buffer socket, thuật toán tạo luồng song song (threading model), thời gian trễ giữa các yêu cầu (delay interval) và chuỗi lệnh thử mật khẩu.
- Máy chủ phản hồi cũng có cấu hình cố định về các cờ giao thức và kích thước cửa sổ TCP (`Init_Win_bytes`).

Hệ quả là hàng nghìn flow được sinh ra trong chiến dịch đó có sự tự tương quan nội tại (Intra-campaign Autocorrelation) cực kỳ mạnh mẽ. Chúng chia sẻ chung một ”dấu vân tay thống kê” (Statistical Footprint) gần như đồng nhất.

7.2.2 Cơ Chế Nội Suy Thay Vì Khái Quát Hóa

Khi áp dụng phép chia ngẫu nhiên (Random Split):

1. Các flow thuộc cùng một chiến dịch tấn công bị xé lẻ và phân tán đều vào cả tập Train và tập Test.
2. Tập Train nhận được 50–70% các flow của chiến dịch FTP và SSH; tập Test nhận 30–50% các flow còn lại của **chính chiến dịch đó**.
3. Thay vì phải học cách tổng quát hóa để phát hiện một cuộc tấn công mới, mô hình cây chỉ cần ghi nhớ ”dấu vân tay” của chiến dịch đã thấy trong tập Train để nhận diện lại các flow của chính chiến dịch đó trong tập Test.

Đây chính là cơ chế tạo ra **Độ lệch đánh giá quá lạc quan (Optimistic Evaluation Bias)**. Điểm số F1 trên 99.9% không chứng minh rằng mô hình học máy thông minh hay có khả năng bảo vệ mạng, mà chỉ chứng minh rằng mô hình đã ”học thuộc lòng” thành công một chiến dịch cụ thể đã qua!

7.3 Bài Học Thực Tiễn MLOps và Quản Trị Ranh Giới Dữ Liệu Trong An Ninh Mạng

Từ các phát hiện thực nghiệm và case study đối soát mã nguồn của nghiên cứu, chúng tôi đúc kết các bài học kỹ nghệ thực tiễn then chốt cho việc phát triển và triển khai hệ thống học máy trong an ninh mạng (MLOps for Cybersecurity):

7.3.1 Hiểm Họa Từ Các Hành Vi Mặc Định Của Thư Viện Học Máy

Case study về cờ `refit=True` của thư viện `scikit-learn` là một lời cảnh tỉnh sâu sắc:

- Trong các bài toán học máy thông thường (nơi dữ liệu giả định *i.i.d.*), việc huấn luyện lại mô hình tốt nhất trên toàn bộ dữ liệu $\mathbf{X}_{\text{train}} \cup \mathbf{X}_{\text{val}}$ sau khi tuning là một thực hành tiêu chuẩn nhằm tận dụng tối đa số lượng mẫu huấn luyện.
- Tuy nhiên, trong an ninh mạng và dữ liệu chuỗi thời gian có sự phân tầng biến thể tấn công (Temporal Subtype Shift), hành động refit này đã vô tình phá vỡ hoàn toàn ranh giới giữa "quá khứ" và "hiện tại". Việc để mô hình tiếp xúc với tập Validation đã biến một bài toán Zero-Shot thành bài toán Supervised Learning, làm sai lệch kết quả từ 0.0000 thành 0.9912.
- **Khuyến nghị MLOps:** Trong các pipeline đánh giá NIDS theo thời gian, các kỹ sư bắt buộc phải tắt cờ refit (`refit=False`) hoặc thực hiện huấn luyện lại một cách tường minh duy nhất trên tập $\mathcal{D}_{\text{train}}$.

7.3.2 Thiết Lập Cơ Chế Khóa Cấu Hình Bất Biến (Immutable Audit Markers)

Việc áp dụng cơ chế đánh dấu mốc kiểm thử `TEST_OPENED.json` gắn liền với mã băm SHA-256 của tệp cấu hình `frozen.json` đã chứng minh tính hiệu quả vượt trội trong việc ngăn chặn rò rỉ dữ liệu qua con người (Human Feedback Leakage). Một quy trình MLOps an toàn bắt buộc phải đảm bảo:

1. Không được phép thay đổi siêu tham số sau khi đã nhìn thấy kết quả kiểm thử.
2. Mọi bước tiền xử lý (loại bỏ đặc trưng, tính giá trị trung vị) bắt buộc phải được đóng gói vào các Pipeline chỉ học (fit) từ tập Train.

7.3.3 Quy Chuẩn 5 Bước Cho Đánh Giá NIDS Bằng Học Máy

Chúng tôi đề xuất một bộ quy chuẩn thực nghiệm gồm 5 bước bắt buộc cho các nghiên cứu ML-NIDS trong tương lai:

1. **Phân tách theo Thời gian (Temporal Split):** Loại bỏ việc sử dụng Random Split làm thước đo đánh giá chính.
2. **Áp dụng Purge và Embargo:** Làm sạch các flow vắt ngang ranh giới và tạo khoảng đệm an toàn giữa các tập dữ liệu.
3. **Báo cáo Độc lập Tỷ lệ Phát hiện Theo Biến thể (Subtype Recall):** Không chỉ báo cáo điểm F1 gộp chung; bắt buộc theo dõi tỷ lệ phát hiện riêng biệt cho từng dạng tấn công mới xuất hiện.
4. **Thực hiện Port Ablation:** Kiểm chứng độ bền vững của mô hình khi không có thông tin công dịch vụ để tránh rơi vào bẫy học vẹt số cổng.

5. **Minh Bạch Hóa Kết Quả Thấp:** Dừng cảm công bố các điểm số thấp trong điều kiện đánh giá thực tế thay vì cố gắng tìm kiếm các phương pháp gượng ép để đạt điểm số hoàn hảo ảo.

Chương 8

GIỚI HẠN VÀ ĐÁNH GIÁ TÍNH HỢP LỆ

Theo chuẩn mực nghiên cứu khoa học thực nghiệm trong công nghệ thông tin và an toàn an ninh mạng, việc tự đánh giá và phản biện các giới hạn nội tại là bắt buộc. Chương này phân tích các mối đe dọa đến tính hợp lệ của nghiên cứu (**Threats to Validity**) theo 4 khía cạnh chuẩn tắc và trình bày các biện pháp giảm thiểu tương ứng (được tổng hợp tại Bảng 8.1).

Bảng 8.1: Tổng hợp các mối đe dọa đến tính hợp lệ của nghiên cứu và giải pháp kiểm soát.

Khía cạnh hợp lệ	Nguy cơ tiềm ẩn	Biện pháp kiểm soát trong nghiên cứu
Internal Validity	Sai lệch do phục hồi thời gian hoặc rò rỉ thông tin ranh giới.	Áp dụng Purge ($q = 60s$) và Embargo ($g = 120s$); loại bỏ 7,632 dòng ranh giới; kiểm tra toàn vẹn băm SHA-256.
Construct Validity	Nhầm lẫn giữa phân loại flow đã đóng và NIDS thời gian thực.	Tuyên bố minh bạch phạm vi Post-Flow Classification; không đo lường độ trễ phát hiện gói tin; không tuyên bố triển khai online.
External Validity	Dữ liệu mô phỏng trong môi trường phòng thí nghiệm (CICIDS2017).	Phân tích cơ chế suy giảm tổng quát hóa; nhấn mạnh yêu cầu đánh giá trên traffic đa dạng và hạ tầng thực tế.
Statistical Validity	Tỷ lệ tấn công thấp ($\sim 2 - 5\%$) gây nhiễu chỉ số Accuracy.	Sử dụng F1-Score, Precision-Recall Curve, AP và FPR làm hệ quy chiếu cốt lõi; loại bỏ sự phụ thuộc vào Accuracy Paradox.

8.1 Tính Hợp Lệ Bên Trong (Internal Validity)

Tính hợp lệ bên trong xem xét liệu các kết luận thực nghiệm có bị bóp méo bởi các yếu tố gây nhiễu (confounding factors) hoặc sai sót trong quy trình xử lý dữ liệu hay không:

1. **Độ chính xác của việc phục hồi nhãn thời gian 24 giờ:** Quy tắc phục hồi dòng thời gian (`reconstruct_timestamp`) được xây dựng dựa trên phân tích dòng thời gian của toàn bộ lưu lượng ngày Tuesday. Mặc dù đã được kiểm chứng tính nhất quán trên 445,909 dòng dữ liệu, đây vẫn là một kỹ thuật phục hồi hậu kỳ trên tệp CSV xuất ra từ CICFlowMeter chứ không phải là nhãn thời gian tuyệt đối của từng gói tin trong tệp

PCAP gốc.

2. **Nguy cơ rò rỉ ranh giới:** Mặc dù đã áp dụng thuật toán Purge ($q = 60s$) và Embargo ($g = 120s$) loại bỏ 7,632 dòng ranh giới, vẫn có thể tồn tại những kết nối TCP nền (Background benign traffic) kéo dài vượt qua ngưỡng embargo mà chưa bị triệt tiêu hoàn toàn. Tuy nhiên, lưu lượng này chỉ thuộc lớp bình thường và không chứa nhân tố tấn công, do đó không làm suy yếu kết luận về sự sụp đổ của mô hình trước biến thể tấn công mới.

8.2 Tính Hợp Lệ Khái Niệm (Construct Validity)

Tính hợp lệ khái niệm đánh giá mức độ tương thích giữa bài toán đo lường thực nghiệm và mục tiêu thực tế của hệ thống an ninh mạng:

1. **Phân loại Flow hoàn tất so với NIDS thời gian thực:** Như đã khẳng định tại Chương 2, hệ thống thực nghiệm hoạt động trên các flow đã đóng hoàn toàn sau khi kết thúc truyền thông. Do đó, các kết quả trong báo cáo này phản ánh năng lực của một hệ thống phân tích nhật ký lưu lượng mạng hậu kiểm (Post-mortem Traffic Analyzer) hơn là một hệ thống phát hiện và ngăn chặn xâm nhập thời gian thực (Inline IPS) có khả năng ngắt kết nối ngay ở những gói tin đầu tiên.
2. **Gộp nhãn nhị phân** (Normal so với Attack): Việc gom chung FTP-Patator và SSH-Patator vào nhãn $y = 1$ có thể che giấu những đặc thù riêng của từng giao thức. Tuy nhiên, việc theo dõi chỉ số phụ Subtype Recall đã giúp khắc phục triệt để hạn chế này.

8.3 Tính Hợp Lệ Bên Ngoài (External Validity)

Tính hợp lệ bên ngoài phản ánh khả năng khái quát hóa của kết quả nghiên cứu sang các môi trường mạng và ngữ cảnh khác:

1. **Dữ liệu môi trường phòng thí nghiệm:** Tập dữ liệu CICIDS2017 được thu thập trong môi trường mạng giả lập của UNB. Mặc dù đã cố gắng mô phỏng lưu lượng người dùng tự nhiên (sử dụng hệ thống B-Profile), lưu lượng này vẫn thiếu đi sự phong phú, phức tạp và nhiễu loạn của các mạng viễn thông hoặc trung tâm dữ liệu quy mô lớn trong thực tế.
2. **Giới hạn trong phạm vi ngày Tuesday:** Bài tập lớn tập trung nghiên cứu chuyên sâu vào hai biến thể tấn công brute force (FTP và SSH) trong ngày thứ Ba. Kết luận về sự

sự đổ của Zero-shot Transfer cần được tiếp tục kiểm chứng trên các dạng tấn công khác như DoS/DDoS (ngày Wednesday) hay Web Attacks (ngày Thursday).

8.4 Tính Hợp Lệ Kết Luận Thống Kê (Statistical Conclusion Validity)

Tính hợp lệ kết luận thống kê liên quan đến độ tin cậy của các phép đo lường và quy mô mẫu:

1. **Mất cân bằng lớp cực đoan:** Số lượng mẫu tấn công trong tập Test chỉ chiếm 2.59% (3,732 trên 144,157 dòng). Để đảm bảo tính tin cậy thống kê, chúng tôi đã sử dụng các chỉ số không phụ thuộc vào lớp đa số như F1-Score, Precision-Recall Curve và Average Precision (AP) thay vì dựa vào Accuracy Paradox.
2. **Độ nhạy của ngưỡng phân loại:** Toàn bộ các kết quả trong bảng đối chuẩn chính được đo lường tại ngưỡng xác suất mặc định $\tau = 0.5$. Mặc dù việc quét ngưỡng (Threshold Tuning) trên tập Validation có thể làm thay đổi nhẹ điểm số, sự sụp đổ cơ bản của các mô hình trước biến thể SSH vẫn giữ nguyên do khoảng cách phân phối quá lớn.

Chương 9

KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

9.1 Tổng Kết Nghiên Cứu và Câu Trả Lời Cho Các Câu Hỏi Nghiên Cứu

Đồ án này đã hoàn thành một cuộc đánh giá thực nghiệm toàn diện, nghiêm ngặt và minh bạch về khả năng phát hiện tấn công dò quét mật khẩu (Brute Force) của các mô hình học máy dạng cây trên tập dữ liệu chuẩn CICIDS2017 Tuesday. Thông qua việc thiết lập một quy trình thực nghiệm chuẩn mực (Canonical Protocol) kiểm soát chặt chẽ rò rỉ thời gian và lưu vết bất biến các artifact, nghiên cứu đã đưa ra câu trả lời tường minh cho 4 câu hỏi nghiên cứu cốt lõi:

1. **Trả lời RQ1 (Hiệu năng Zero-Shot Subtype Transfer theo thời gian):** Khi mô hình học máy dạng cây chỉ được huấn luyện trên dữ liệu quá khứ chứa một dạng tấn công Brute Force (`FTP-Patator`), mô hình **hoàn toàn không có khả năng tự động khái quát hóa để nhận diện dạng tấn công Brute Force mới (`SSH-Patator`) xuất hiện trong tương lai**. Trên tập Test theo thời gian chính thức, cả 3 mô hình đều sụp đổ: Decision Tree và XGBoost đạt $F1\text{-Score} = 0.0000$ (không bắt được mẫu SSH nào), trong khi Random Forest chiến thắng chỉ đạt $F1\text{-Score} = 0.0037$ với tỷ lệ phát hiện SSH vồn vện **0.19%** (7/3,732 flow).
2. **Trả lời RQ2 (Độ lệch đánh giá của phép chia ngẫu nhiên - Optimistic Bias):** Phép chia ngẫu nhiên (Random Split) tạo ra **sự thổi phồng kết quả cực kỳ nghiêm trọng**, làm sai lệch hoàn toàn nhận thức về năng lực thực tế của mô hình. Trong khi trên phân tách theo thời gian F1 chỉ đạt ≤ 0.0037 , thì trên Random Split, cả 3 mô hình đều đạt $F1\text{-Score} \geq 0.9942 - 0.9997$. Khoảng cách sai lệch hiệu năng ($\Delta F1\text{-Score}$) trên tập kiểm định lên tới **0.2816**. Hiện tượng này xảy ra do phép chia ngẫu nhiên đã xé lẻ các flow thuộc cùng một chiến dịch tấn công vào cả hai tập, vi phạm giả thiết *i.i.d.* và biến bài toán tổng quát hóa thành bài toán nhận dạng lại một chiến dịch đã học.
3. **Trả lời RQ3 (Vai trò của cổng dịch vụ và các đặc trưng hành vi):** Cổng dịch vụ đích (`Destination Port`) đóng vai trò là một **lối tắt học vẹt (Shortcut Feature) áp đảo**. Phân tích SHAP chứng minh `Destination Port` có mức độ đóng góp trung bình lớn

nhất (0.1237, gấp 3.6 lần đặc trưng xếp thứ hai), và Cây Quyết Định phân chia ngay ở nút gốc tại ngưỡng ≤ 21.5 . Khi loại bỏ cổng dịch vụ (Port Ablation), tỷ lệ nhận diện SSH có tăng nhẹ từ 0.00% lên 0.19% – 0.38%, nhưng **hiệu năng tổng thể vẫn sụp đổ hoàn toàn ($F1\text{-Score} \leq 0.0074$)**. Điều này chứng minh sự thất bại của NIDS không chỉ do số cổng, mà do sự phân kỳ sâu sắc về phân phối kích thước gói tin và thời gian trễ giữa các giao thức.

4. **Trả lời RQ4 (Tác động của giao thức huấn luyện lại - Refit Impact):** Hành vi mặc định `refit=True` của thư viện `scikit-learn` khi sử dụng kiểm định chéo trên tập gộp Train + Validation đã **vô tình phá vỡ ranh giới dữ liệu**. Mô hình bị huấn luyện lại trên 1,886 mẫu SSH từ tập Validation, biến một bài toán Zero-Shot thành bài toán Supervised Learning thông thường và đẩy điểm số Test F1 từ **0.0000 lên 0.9912**. Đây là bài học thực tiễn đắt giá về việc kiểm soát ranh giới dữ liệu trong MLOps an ninh mạng.

9.2 Đóng Góp Khoa Học và Ý Nghĩa Thực Tiễn

- **Về mặt học thuật:** Bài tập lớn là một trong những công trình đầu tiên tại Việt Nam dừng cảm công bố và phân tích chi tiết sự suy giảm hiệu năng của mô hình học máy trên NIDS chuỗi thời gian, cung cấp bằng chứng thực nghiệm rõ ràng phản bác lại trào lưu ”chạy đua F1 > 99%” thiếu thực tế.
- **Về mặt phương pháp luận:** Đề xuất và hoàn thiện quy chuẩn đánh giá NIDS 5 bước với kỹ thuật Purge và Embargo, kiểm soát ranh giới dữ liệu và theo dõi tỷ lệ phát hiện chi tiết theo từng biến thể tấn công (Subtype Recall).
- **Về mặt kỹ thuật MLOps:** Cảnh báo nguy cơ tiềm ẩn từ các cò tự động của thư viện học máy và chứng minh sự cần thiết của các cơ chế đánh dấu mốc kiểm thử bất biến (`TEST_OPENED.json`).

9.3 Hướng Nghiên Cứu Tiếp Theo

Từ các kết quả và hạn chế đã chỉ ra, các hướng nghiên cứu mở rộng đầy triển vọng bao gồm:

1. **Học Thích Ứng Miền và Học Vài Mẫu (Domain Adaptation & Few-Shot):** Xây dựng các mạng nơ-ron học biểu diễn (Representation Learning) nhằm trích xuất các đặc trưng phi tuyến bất biến qua các giao thức (Protocol-invariant Features), giúp mô hình có thể phát hiện tấn công mới chỉ với một lượng rất nhỏ mẫu mới.

2. **Học Liên Tục (Continual / Lifelong Learning) trong NIDS:** Thiết kế các cơ chế cập nhật trọng số mô hình trực tuyến theo thời gian thực (Online Continual Updating) mà không gặp phải hiện tượng quên thảm họa (Catastrophic Forgetting) đối với các dạng tấn công cũ.
3. **Đánh giá Đa Ngày trên CICIDS2017:** Mở rộng quy chuẩn phân tách theo thời gian sang các ngày còn lại trong tuần (như DoS/DDoS ngày Wednesday và Web Attacks ngày Thursday) để xây dựng một bức tranh toàn cảnh về độ bền vững của ML-NIDS.

TÀI LIỆU THAM KHẢO

- [1] R. Sommer and V. Paxson, “Outside the closed world: On using machine learning for network intrusion detection,” in *2010 IEEE Symposium on Security and Privacy (SP)*, IEEE, 2010, pp. 305–316.
- [2] D. Arp et al., “Dos and don’ts of machine learning in computer security,” in *31st USENIX Security Symposium (USENIX Security 22)*, 2022, pp. 3971–3988.
- [3] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward generating a new intrusion detection dataset and intrusion traffic characterization,” in *Proceedings of the 4th International Conference on Information Systems Security and Privacy (ICISSP)*, 2018, pp. 108–116.
- [4] J. R. Quinlan, “Induction of decision trees,” *Machine learning*, vol. 1, no. 1, pp. 81–106, 1986.
- [5] L. Breiman, “Random forests,” *Machine learning*, vol. 45, no. 1, pp. 5–32, 2001.
- [6] T. Chen and C. Guestrin, “XGBoost: A scalable tree boosting system,” in *Proceedings of the 22nd ACM SIGKDD International Conference on Knowledge Discovery and Data Mining*, 2016, pp. 785–794.
- [7] J. Davis and M. Goadrich, “The relationship between Precision-Recall and ROC curves,” in *Proceedings of the 23rd International Conference on Machine Learning (ICML)*, 2006, pp. 233–240.
- [8] R. Geirhos et al., “Shortcut learning in deep neural networks,” *Nature Machine Intelligence*, vol. 2, no. 11, pp. 665–673, 2020.
- [9] F. Pendlebury, F. Pierazzi, R. Jordaney, J. Kinder, and L. Cavallaro, “TESSERACT: Eliminating experimental bias in malware classification across space and time,” in *28th USENIX Security Symposium (USENIX Security 19)*, 2019, pp. 729–746.
- [10] S. M. Lundberg and S.-I. Lee, “A unified approach to interpreting model predictions,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 30, 2017, pp. 4765–4774.

Phụ lục A

HƯỚNG DẪN CÀI ĐẶT VÀ TÁI LẬP THỰC NGHIỆM

A.1 Yêu Cầu Môi Trường và Cài Đặt Phụ Thuộc

Để tái lập toàn bộ các kết quả thực nghiệm trong báo cáo, người nghiên cứu cần chuẩn bị môi trường Python ≥ 3.11 và thực hiện các bước sau:

Listing A.1: Thiết lập môi trường ảo và cài đặt thư viện

```
# 1. Clone repository
git clone https://github.com/Duc-AnhTp/cicids-bruteforce-ids.git
cd cicids-bruteforce-ids

# 2. Tao va kich hoat moi truong ao
python -m venv .venv
# Tren Linux / macOS:
source .venv/bin/activate
# Tren Windows PowerShell:
.\.venv\Scripts\Activate.ps1

# 3. Cai dat cac thu vien phu thuoc da kiem chung
pip install -e .
```

A.2 Chuẩn Bị Dữ Liệu và Phân Tách

Listing A.2: Thực hiện làm sạch và phân tách dữ liệu chuẩn mực

```
# Kiem tra ma bam SHA-256 cua tep CSV goc
python -m ids check-integrity data/raw/Tuesday-WorkingHours.pcap_ISCX.csv

# Chay quy trinh phuc hoi timestamp va chia tach du lieu theo thoi gian
python scripts/prepare_splits.py

# Tien xu ly Train-only va loai bo 10 dac trung hang so
python scripts/preprocess_data.py
```

A.3 Chạy Thực Nghiệm và Kiểm Thử Đóng Băng

Listing A.3: Huấn luyện, tìm kiếm siêu tham số và đánh giá tập Test

```
# Chạy toàn bộ quy trình benchmark W3-W4 (đóng băng và đánh giá Test)
python scripts/run_remaining.py

# Sinh lại toàn bộ macro số liệu và bảng LaTeX từ artifact
python scripts/report/generate_latex_registry.py

# Chạy bộ kiểm thử đơn vị (Unit tests)
pytest tests/ -v
```

Phụ lục B

KHÔNG GIAN SIÊU THAM SỐ VÀ CẤU HÌNH TỐI ƯU

Phụ lục này cung cấp chi tiết toàn bộ các cấu hình siêu tham số tối ưu được lựa chọn từ tệp lưu vết `artifacts/week3_week4/frozen.json` và `validation_winners.csv`:

Bảng B.1: Chi tiết tham số tối ưu của 12 mô hình được lựa chọn trên tập Validation.

Kịch bản thực nghiệm	Mô hình	Phân tách	Cổng	Tham số tối ưu được khóa
W3-01	Decision Tree	Time	With Port	<code>criterion='gini', max_depth=6, min_samples_leaf=5</code>
W3-03	Random Forest	Time	With Port	<code>n_estimators=100, max_depth=16, min_samples_leaf=5</code>
W3-05	XGBoost	Time	With Port	<code>n_estimators=200, max_depth=4, learning_rate=0.08</code>
W3-01	Decision Tree	Time	Without Port	<code>criterion='gini', max_depth=8, min_samples_leaf=5</code>
W3-03	Random Forest	Time	Without Port	<code>n_estimators=100, max_depth=10, min_samples_leaf=5</code>
W3-05	XGBoost	Time	Without Port	<code>n_estimators=200, max_depth=4, learning_rate=0.08</code>
W3-02	Decision Tree	Random	With Port	<code>criterion='gini', max_depth=12, min_samples_leaf=5</code>
W3-04	Random Forest	Random	With Port	<code>n_estimators=100, max_depth=None, min_samples_leaf=5</code>
W3-06	XGBoost	Random	With Port	<code>n_estimators=200, max_depth=6, learning_rate=0.08</code>
W3-02	Decision Tree	Random	Without Port	<code>criterion='gini', max_depth=None, min_samples_leaf=5</code>
W3-04	Random Forest	Random	Without Port	<code>n_estimators=150, max_depth=None, min_samples_leaf=5</code>
W3-06	XGBoost	Random	Without Port	<code>n_estimators=200, max_depth=6, learning_rate=0.08</code>

Phụ lục C

DANH MỤC ĐẦY ĐỦ CÁC ĐẶC TRƯNG MẠNG

Bảng sau liệt kê đầy đủ 67 đặc trưng mạng được sử dụng trong kịch bản `with_port` (trong kịch bản `without_port`, đặc trưng số 1 `Destination Port` bị loại bỏ):

STT	Tên đặc trưng trong dữ liệu	Ý nghĩa giao thức và thống kê luồng mạng
1	<code>Destination Port</code>	Cổng dịch vụ mạng đích (21 FTP, 22 SSH, 80 HTTP, 443 HTTPS)
2	<code>Flow Duration</code>	Tổng thời lượng tồn tại của phiên truyền thông luồng (μs)
3	<code>Total Fwd Packets</code>	Tổng số lượng gói tin truyền theo hướng đi (Client $\rightarrow$ Server)
4	<code>Total Backward Packets</code>	Tổng số lượng gói tin truyền theo hướng về (Server $\rightarrow$ Client)
5	<code>Total Length of Fwd Packets</code>	Tổng kích thước dữ liệu gói tin truyền theo hướng đi (bytes)
6	<code>Total Length of Bwd Packets</code>	Tổng kích thước dữ liệu gói tin truyền theo hướng về (bytes)
7	<code>Fwd Packet Length Max</code>	Kích thước gói tin lớn nhất theo hướng đi (bytes)
8	<code>Fwd Packet Length Min</code>	Kích thước gói tin nhỏ nhất theo hướng đi (bytes)
9	<code>Fwd Packet Length Mean</code>	Kích thước gói tin trung bình theo hướng đi (bytes)
10	<code>Fwd Packet Length Std</code>	Độ lệch chuẩn kích thước gói tin theo hướng đi
11	<code>Bwd Packet Length Max</code>	Kích thước gói tin lớn nhất theo hướng về (bytes)
12	<code>Bwd Packet Length Min</code>	Kích thước gói tin nhỏ nhất theo hướng về (bytes)
13	<code>Bwd Packet Length Mean</code>	Kích thước gói tin trung bình theo hướng về (bytes)
14	<code>Bwd Packet Length Std</code>	Độ lệch chuẩn kích thước gói tin theo hướng về
15	<code>Flow Bytes/s</code>	Tốc độ truyền tải byte trên một đơn vị giây

STT	Tên đặc trưng trong dữ liệu	Ý nghĩa giao thức và thống kê luồng mạng
16	Flow Packets/s	Tốc độ truyền tải gói tin trên một đơn vị giây
17	Flow IAT Mean	Thời gian trễ trung bình giữa các gói tin liên tiếp của flow
18	Flow IAT Std	Độ lệch chuẩn thời gian trễ giữa các gói tin của flow
19	Flow IAT Max	Thời gian trễ lớn nhất giữa hai gói tin liên tiếp của flow
20	Flow IAT Min	Thời gian trễ nhỏ nhất giữa hai gói tin liên tiếp của flow
21	Fwd IAT Total	Tổng thời gian trễ giữa các gói tin theo hướng đi
22	Fwd IAT Mean	Thời gian trễ trung bình giữa các gói tin theo hướng đi
23	Fwd IAT Std	Độ lệch chuẩn thời gian trễ giữa các gói tin theo hướng đi
24	Fwd IAT Max	Thời gian trễ lớn nhất giữa các gói tin theo hướng đi
25	Fwd IAT Min	Thời gian trễ nhỏ nhất giữa các gói tin theo hướng đi
26	Bwd IAT Total	Tổng thời gian trễ giữa các gói tin theo hướng về
27	Bwd IAT Mean	Thời gian trễ trung bình giữa các gói tin theo hướng về
28	Bwd IAT Std	Độ lệch chuẩn thời gian trễ giữa các gói tin theo hướng về
29	Bwd IAT Max	Thời gian trễ lớn nhất giữa các gói tin theo hướng về
30	Bwd IAT Min	Thời gian trễ nhỏ nhất giữa các gói tin theo hướng về
31	Fwd PSH Flags	Số lần cờ PSH được bật theo hướng đi
32	Fwd Header Length	Tổng độ dài phần header của các gói tin hướng đi (bytes)
33	Bwd Header Length	Tổng độ dài phần header của các gói tin hướng về (bytes)
34	Fwd Packets/s	Tốc độ truyền gói tin hướng đi trên mỗi giây
35	Bwd Packets/s	Tốc độ truyền gói tin hướng về trên mỗi giây
36	Min Packet Length	Kích thước gói tin nhỏ nhất quan sát được trong toàn bộ flow
37	Max Packet Length	Kích thước gói tin lớn nhất quan sát được trong toàn bộ flow
38	Packet Length Mean	Độ dài trung bình của tất cả các gói tin trong flow

STT	Tên đặc trưng trong dữ liệu	Ý nghĩa giao thức và thống kê luồng mạng
39	Packet Length Std	Độ lệch chuẩn kích thước toàn bộ các gói tin trong flow
40	Packet Length Variance	Phương sai phân bố kích thước các gói tin trong flow
41	FIN Flag Count	Số lượng cờ FIN xuất hiện trong flow (báo hiệu đóng kết nối)
42	SYN Flag Count	Số lượng cờ SYN xuất hiện trong flow (báo hiệu bắt tay TCP)
43	RST Flag Count	Số lượng cờ RST xuất hiện trong flow (thiết lập lại kết nối)
44	PSH Flag Count	Số lượng cờ PSH xuất hiện trong flow (đẩy dữ liệu lên tầng app)
45	ACK Flag Count	Số lượng cờ ACK xuất hiện trong flow (xác nhận gói tin)
46	URG Flag Count	Số lượng cờ URG xuất hiện trong flow (dữ liệu khẩn cấp)
47	ECE Flag Count	Số lượng cờ ECE xuất hiện trong flow (thông báo nghẽn mạng)
48	Down/Up Ratio	Tỷ lệ lưu lượng tải xuống so với tải lên
49	Average Packet Size	Kích thước gói tin trung bình tổng thể của flow
50	Avg Fwd Segment Size	Kích thước phân đoạn TCP trung bình theo hướng đi
51	Avg Bwd Segment Size	Kích thước phân đoạn TCP trung bình theo hướng về
52	Subflow Fwd Packets	Số lượng gói tin trung bình trong một subflow hướng đi
53	Subflow Fwd Bytes	Số lượng byte trung bình trong một subflow hướng đi
54	Subflow Bwd Packets	Số lượng gói tin trung bình trong một subflow hướng về
55	Subflow Bwd Bytes	Số lượng byte trung bình trong một subflow hướng về
56	Init_Win_bytes_forward	Kích thước cửa sổ TCP nhận ban đầu phía client (bytes)
57	Init_Win_bytes_backward	Kích thước cửa sổ TCP nhận ban đầu phía server (bytes)
58	act_data_pkt_fwd	Số lượng gói tin hướng đi thực sự có mang payload dữ liệu
59	min_seg_size_forward	Kích thước phân đoạn tối thiểu được quan sát phía forward
60	Active Mean	Thời gian hoạt động trung bình trước khi chuyển sang trạng thái chờ
61	Active Std	Độ lệch chuẩn thời gian hoạt động của flow
62	Active Max	Thời gian hoạt động tối đa của flow

STT	Tên đặc trưng trong dữ liệu	Ý nghĩa giao thức và thống kê luồng mạng
63	Active Min	Thời gian hoạt động tối thiểu của flow
64	Idle Mean	Thời gian chờ (không có traffic) trung bình của flow
65	Idle Std	Độ lệch chuẩn thời gian chờ của flow
66	Idle Max	Thời gian chờ tối đa của flow
67	Idle Min	Thời gian chờ tối thiểu của flow

Phụ lục D

QUY TẮC RỄ NHÁNH CỦA CÂY QUYẾT ĐỊNH

Dưới đây là cấu trúc logic và các quy tắc phân loại văn bản được trích xuất trực tiếp từ mô hình Decision Tree huấn luyện trên tập Train theo thời gian trong kịch bản Bóc tách Cổng mạng (`without_port`). Khi không có đặc trưng Destination Port, mô hình buộc phải rẽ nhánh dựa trên hình thái thống kê gói tin với nút gốc là Average Packet Size ≤ 14.12 (đối chiếu với cấu trúc cây kịch bản Có cổng tại Mục 6.6.2):

Listing D.1: Toàn văn quy tắc rẽ nhánh cấp cao của Cây Quyết Định (`max_depth=4`)

```
# Top Decision Rules for DecisionTree (max_depth=4 preview)
# Total Depth: 9, Leaves: 17

|--- Average Packet Size <= 14.12
|   |--- Average Packet Size <= 9.29
|       |--- SYN Flag Count <= 0.50
|           |--- Total Length of Bwd Packets <= 57.00
|               |--- Flow IAT Min <= 36509.50
|                   |--- class: 0 (Normal)
|                       |--- Flow IAT Min > 36509.50
|                           |--- truncated branch of depth 5
|                               |--- Total Length of Bwd Packets > 57.00
|                                   |--- class: 1 (Attack)
|                                       |--- SYN Flag Count > 0.50
|                                           |--- Fwd Packet Length Mean <= 5.25
|                                               |--- class: 0 (Normal)
|                                                   |--- Fwd Packet Length Mean > 5.25
|                                                       |--- class: 1 (Attack)
|   |--- Average Packet Size > 9.29
|       |--- Packet Length Std <= 14.32
|           |--- Fwd Packet Length Std <= 14.42
|               |--- Flow IAT Max <= 1.50
|                   |--- truncated branch of depth 4
|                       |--- Flow IAT Max > 1.50
|                           |--- class: 1 (Attack)
|                               |--- Fwd Packet Length Std > 14.42
```

```
|   |   |   |   |--- class: 0 (Normal)
|   |   |--- Packet Length Std > 14.32
|   |   |   |--- class: 0 (Normal)
|--- Average Packet Size > 14.12
|   |--- class: 0 (Normal)
```